

100

SOC INVESTIGATION SCENARIOS

A Practical Step-by-Step Playbook for Security Operations

**PHISHING / MALWARE / CREDENTIAL ABUSE / VPN / DNS / POWERSHELL
RANSOMWARE / CLOUD / INSIDER RISK / WEB ATTACKS**

2026 EDITION

Designed for SOC L1-L3 analysts, incident responders, detection engineers, threat hunters and blue-team training.

The Universal SOC Investigation Method

- 1. Validate the alert** Confirm the alert's raw evidence, time, entities, detection logic and control action. "Blocked", "detected", "allowed", "quarantined" and "failed" mean different things.
- 2. Build the timeline** Anchor the alert time, then look backward for initial access and forward for execution, persistence, privilege, lateral movement, collection, C2, exfiltration and impact.
- 3. Scope the entities** Identify every related user, host, IP, domain, file, process, application, session, mailbox, cloud resource and business service.
- 4. Correlate independent evidence** Do not rely on one telemetry source. Combine identity, endpoint, network, email, cloud, application and business records so one source can validate or contradict another.
- 5. Test competing hypotheses** Ask what evidence would exist if the event were malicious, and what evidence would exist if it were benign. Keep both hypotheses alive until the data meaningfully favours one.
- 6. Determine attack progression** Map observed behaviour to attacker objectives. Separate capability or attempted action from confirmed execution and impact.
- 7. Contain proportionately** Contain the specific risk that is supported: message purge, token revocation, password reset, host isolation, domain block, privilege removal, session termination, vulnerable service mitigation or broader incident activation.
- 8. Preserve evidence and business context** Record raw logs, identifiers, timestamps, query logic, affected data/services and change/ticket context. This makes the investigation repeatable and auditable.
- 9. Define closure criteria** State what must be true before closure: no active persistence, compromised identities recovered, malicious infrastructure blocked, affected assets remediated, scope completed and residual monitoring assigned.
- 10. Improve detection** Every completed investigation should create value: rule tuning, new correlation logic, logging gaps, playbook improvements, threat-hunting ideas or control changes.

Practical Severity Matrix

Severity	Typical meaning	Examples	Expected SOC posture
Critical	Active or widespread compromise; material business impact possible	Ransomware spreading; privileged tenant/domain compromise; active exfiltration	Immediate incident command, containment and senior escalation
High	Confirmed compromise or high-confidence attacker activity with meaningful scope	Successful account takeover; malware execution with C2; web shell	Rapid containment, scoping and incident escalation
Medium	Suspicious activity requiring investigation; impact not yet established	Blocked malware with uncertain execution; risky sign-in; suspicious DNS	Prompt analysis, evidence correlation and targeted containment if confirmed
Low	Weak signal, blocked attempt, policy event or likely benign anomaly	Single rejected scan; false-positive-prone detection; authorised rare behaviour	Validate, document, tune if needed and close when evidence supports

Alert-State Vocabulary

Detected: The security control observed activity that matched logic. This alone does not tell you whether execution or compromise occurred.

Blocked: The control reports prevention of a specific action. Validate whether an earlier or alternate action succeeded and whether follow-on activity exists.

Allowed: A network or application control permitted traffic. Allowed traffic is not proof of compromise; correlate endpoint, identity and application outcomes.

Quarantined: A file/object was moved or neutralised. Check whether it executed before quarantine or whether persistence/secondary components remain.

Failed authentication: The login did not succeed. Determine whether another source, protocol or later attempt succeeded.

Successful authentication: The credentials/session were accepted. The investigation must still establish whether the user, device and subsequent actions were legitimate.

True positive: The detection correctly identified the behaviour it was designed to detect. A true-positive alert may still represent a blocked attempt rather than a successful incident.

Incident: Unauthorised activity has meaningful security impact or requires coordinated response. Use organisational classification criteria rather than equating every true positive with an incident.

Contents

Phishing & Social Engineering — Email, collaboration, user interaction and identity pivots

- 001 Spoofed Microsoft 365 Password Reset
- 002 Invoice HTML Attachment Credential Phish
- 003 OAuth Consent Phishing via Shared Document
- 004 QR Code Phishing from Corporate Email
- 005 BEC Reply-Chain Hijack
- 006 Internal Spearphish from Compromised Mailbox
- 007 Fake Voicemail Notification
- 008 MFA Expiry Portal Phish
- 009 Recruitment ZIP with LNK
- 010 CEO Gift-Card Request
- 011 Vendor Bank-Detail Change Fraud
- 012 Malicious Teams Message from Trusted User

Malware & Endpoint Compromise — EDR, process trees, file telemetry, persistence and C2

- 013 EDR Blocks Unknown Executable
- 014 Word Spawns Suspicious Child Process
- 015 LNK Launches Script Interpreter
- 016 Signed Binary Proxy Execution
- 017 Browser Downloaded Infostealer
- 018 USB-Delivered Malware
- 019 Scheduled Task Persistence
- 020 Suspicious Windows Service
- 021 DLL Sideloaded Pattern
- 022 MSHTA Executes Remote Content
- 023 Archive Extraction Followed by Payload
- 024 C2 Beacon After Quarantined File

Credential Abuse & Identity Attacks — Authentication, MFA, privilege, tokens and account takeover

- 025 Password Spray Against Cloud Accounts
- 026 Brute Force Followed by Success
- 027 Impossible Travel Sign-In
- 028 MFA Fatigue / Push Bombing
- 029 New MFA Method Added
- 030 Mailbox Rules After Account Takeover
- 031 Service Account Interactive Logon
- 032 Dormant Account Reactivated
- 033 Privileged Admin Login from New Host
- 034 Kerberoasting Indicators
- 035 Suspicious LSASS Access
- 036 Leaked Corporate Credentials Found Externally

VPN & Remote Access — Remote access, device posture, assigned IPs and internal pivots

- 037 VPN Login from Unusual Country
- 038 Concurrent VPN Sessions
- 039 VPN Success After Password Spray
- 040 Legacy VPN Protocol Use
- 041 Impossible Travel Across VPN and SaaS
- 042 High Data Transfer Over VPN
- 043 Privileged VPN Login After Hours
- 044 VPN from Hosting / Anonymous Infrastructure

DNS & Network Resolution — Resolver behaviour, rare domains, tunnelling and C2

- 045 Domain Generation Algorithm Pattern
- 046 Possible DNS Tunnelling
- 047 Newly Registered Domain Contact
- 048 Dynamic DNS Service Usage
- 049 Repeated NXDOMAIN Burst
- 050 DNS to Known C2 Domain
- 051 Rare Domain After Office Process
- 052 Unexpected DNS-over-HTTPS Process

PowerShell & Script Abuse — Command-line analysis, script logging and living-off-the-land behaviour

- 053 Encoded PowerShell Command

- 054 PowerShell Download Cradle
- 055 Hidden Window and Execution-Policy Bypass
- 056 Base64 Decode Followed by Execution
- 057 PowerShell Adds Security Exclusion
- 058 PowerShell Creates Scheduled Task
- 059 Remote PowerShell / WinRM Activity
- 060 Office Launches PowerShell
- 061 Invoke-Expression on Downloaded Content
- 062 PowerShell Stages Data for Exfiltration

Ransomware & Extortion — Precursor detection, containment, lateral movement, exfiltration and impact

- 063 Mass File Rename and Encryption Pattern
- 064 Shadow Copy Deletion Before Impact
- 065 Backup Services Stopped
- 066 SMB Lateral Movement Before Encryption
- 067 PsExec-Style Ransomware Propagation
- 068 RDP Intrusion Followed by Encryption
- 069 Domain Admin Compromise in Ransomware Case
- 070 Large Data Staging Before Encryption
- 071 Exfiltration to Cloud Storage Before Ransomware
- 072 Safe Mode Reboot Preceding Encryption
- 073 Virtualisation Host Ransomware Indicators
- 074 Ransom Note Found but No Encryption Observed

Cloud & SaaS — Cloud audit, OAuth, tokens, storage, roles and session compromise

- 075 Microsoft 365 Risky Sign-In with Data Access
- 076 Malicious OAuth Application Consent
- 077 Mass SharePoint/OneDrive Download
- 078 External Mail Forwarding Rule
- 079 Privileged Cloud Role Assignment
- 080 AWS Access Key Used from New Infrastructure
- 081 Cloud Storage Made Public
- 082 Service Principal Credential Added
- 083 Unmanaged Device Accesses Sensitive SaaS
- 084 Session Cookie / Token Reuse

Insider Risk & Data Misuse — Legitimate access, DLP, intent-neutral evidence and governance

- 085 Mass Copy to Removable Media
- 086 Upload to Personal Cloud Storage
- 087 Departing Employee Repository Clone
- 088 Unusual Privileged Database Queries
- 089 Mailbox Export / eDiscovery Activity
- 090 After-Hours Source Code Archive
- 091 Repeated Security Policy Bypass Attempts
- 092 Legitimate Access Used to Share Sensitive Data

Web & Application Attacks — WAF, application, API, server and database correlation

- 093 SQL Injection Attempt Against Internet Portal
- 094 Potential Web Shell on Server
- 095 Directory Traversal Attempt
- 096 Credential Stuffing Against Customer Portal
- 097 API Token Abuse
- 098 Suspicious File Upload to Web Application
- 099 Server-Side Request Forgery Attempt
- 100 WAF Block Followed by Host Compromise Indicators

Phishing & Social Engineering

Email, collaboration, user interaction and identity pivots

Primary evidence: original message/header, message trace, click telemetry, proxy/browser, identity, collaboration audit, EDR.

001. Spoofed Microsoft 365 Password Reset

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.002 Spearphishing Link; T1078 Valid Accounts	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.73

Initial alert: Secure email gateway flags a message impersonating the identity team and linking to a look-alike sign-in portal.

Investigation objective: Determine whether any recipient clicked, entered credentials, approved MFA, or had a subsequent account takeover.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Compare display name, envelope sender, Reply-To, SPF/DKIM/DMARC outcomes and Received chain.
- 7. Scenario-specific check 2:** Search click-tracking/proxy logs for the landing URL and redirect chain.
- 8. Scenario-specific check 3:** Correlate any click with identity sign-ins, MFA prompts, token issuance and mailbox changes.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known

Evidence that raises confidence	Evidence that may support benign/contained activity
use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare display name, envelope sender, Reply-To, SPF/DKIM/DMARC outcomes and Received chain.	application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate any click with identity sign-ins, MFA prompts, token issuance and mailbox changes.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

002. Invoice HTML Attachment Credential Phish

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.001 Spearphishing Attachment; T1056 Input Capture	User: svc_reports Host: SRV-APP-03 External IP: 203.0.113.91

Initial alert: Accounts Payable receives an HTML invoice attachment that renders a fake cloud sign-in form.

Investigation objective: Prove whether the attachment was opened, whether credentials were submitted, and whether the campaign reached other mailboxes.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Hash and detonate the HTML safely; extract form action, script references and redirectors.
- 7. Scenario-specific check 2:** Search email telemetry for the same sender, subject, attachment hash and embedded domains.
- 8. Scenario-specific check 3:** Check browser/proxy telemetry and identity logs around the user interaction time.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Hash and detonate the HTML safely; extract form action, script references and redirectors.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check browser/proxy telemetry and identity logs around the user interaction time.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

003. OAuth Consent Phishing via Shared Document

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Email gateway / user report / collaboration audit	T1528 Steal Application Access Token; T1098 Account Manipulation	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.161

Initial alert: A user grants a newly registered OAuth application permissions after opening a fake shared-document invitation.

Investigation objective: Determine the permissions granted, token use, accessed data and whether persistence remains through consent.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Review OAuth consent/audit events and application registration details.
- 7. Scenario-specific check 2:** Identify delegated scopes such as Mail.Read, Files.Read, offline_access or directory permissions.
- 8. Scenario-specific check 3:** Revoke consent/tokens and search for activity executed by the application rather than the user.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review OAuth consent/audit events and application registration details.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Revoke consent/tokens and search for activity executed by the application rather than the user.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

004. QR Code Phishing from Corporate Email

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.002 Spearphishing Link; T1056 Input Capture	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.202

Initial alert: A message contains a QR code leading mobile users to a credential-harvesting site.

Investigation objective: Trace an attack where URL inspection at the email layer may not expose the final destination.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Decode the QR in a controlled analysis environment and capture the full redirect chain.
- 7. Scenario-specific check 2:** Search mobile/browser and identity telemetry because the click may occur off the managed workstation.
- 8. Scenario-specific check 3:** Check for device registration, new MFA methods or token activity after the scan.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Decode the QR in a controlled analysis environment and capture the full redirect chain.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check for device registration, new MFA methods or token activity after the scan.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

005. BEC Reply-Chain Hijack

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566 Phishing; T1078 Valid Accounts	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.44

Initial alert: A trusted supplier conversation suddenly contains revised payment instructions from the same thread.

Investigation objective: Determine whether the supplier mailbox, an internal mailbox, or only the message content was compromised.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Compare historic sender infrastructure, Reply-To values, writing pattern and message headers with prior legitimate messages.
- 7. Scenario-specific check 2:** Check internal mailbox sign-ins, forwarding rules, inbox rules and delegated access.
- 8. Scenario-specific check 3:** Validate payment changes out-of-band using an existing trusted contact channel.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare historic sender infrastructure, Reply-To values, writing pattern and message headers with prior legitimate messages.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Validate payment changes out-of-band using an existing trusted contact channel.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

006. Internal Spearphish from Compromised Mailbox

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1534 Internal Spearphishing; T1078 Valid Accounts	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.73

Initial alert: Multiple employees receive a malicious SharePoint-style link from a legitimate internal mailbox.

Investigation objective: Contain the compromised sender and establish how far the internal campaign propagated.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Prioritise the sender account as potentially compromised rather than treating the message as simple spoofing.
- 7. Scenario-specific check 2:** Search sent items/message trace for all recipients and subsequent forwards.
- 8. Scenario-specific check 3:** Review sign-in, token, inbox-rule and OAuth activity for the sender before and after campaign launch.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Prioritise the sender account as potentially compromised rather than treating the message as simple spoofing.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review sign-in, token, inbox-rule and OAuth activity for the sender before and after campaign launch.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

007. Fake Voicemail Notification

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.002 Spearphishing Link; T1621 Multi-Factor Authentication Request Generation	User: n.sofia Host: WS-HR-017 External IP: 203.0.113.91

Initial alert: A voicemail-themed message directs the user to a fake sign-in page and requests MFA approval.

Investigation objective: Determine whether credential theft and MFA social engineering succeeded.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Inspect the link destination, page title, favicon and credential-posting endpoint.
- 7. Scenario-specific check 2:** Correlate click time with failed/successful sign-ins and MFA prompt records.
- 8. Scenario-specific check 3:** Ask whether the user entered a password or approved an unexpected MFA request; preserve technical evidence regardless of user recollection.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Inspect the link destination, page title, favicon and credential-posting endpoint.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Ask whether the user entered a password or approved an unexpected MFA request; preserve technical evidence regardless of user recollection.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

008. MFA Expiry Portal Phish

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.002 Spearphishing Link; T1098.005 Device Registration	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.161

Initial alert: A fake security notice claims the user must re-register MFA within 24 hours.

Investigation objective: Check for both credential capture and unauthorised MFA method registration.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Review identity audit logs for authentication-method additions/removals.
- 7. Scenario-specific check 2:** Search sign-ins for new device identifiers, unfamiliar IPs and token refreshes.
- 8. Scenario-specific check 3:** Invalidate sessions and require trusted re-registration when evidence supports compromise.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review identity audit logs for authentication-method additions/removals.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Invalidate sessions and require trusted re-registration when evidence supports compromise.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

009. Recruitment ZIP with LNK

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566.001 Spearphishing Attachment; T1204.002 Malicious File	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.202

Initial alert: HR receives a password-protected archive containing a resume-looking Windows shortcut.

Investigation objective: Determine whether the LNK launched script content or downloaded a second-stage payload.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Extract the archive and parse shortcut target/arguments in an isolated environment.
- 7. Scenario-specific check 2:** Search EDR for explorer.exe -> powershell.exe/cmd.exe/mshta.exe or similar child-process chains.
- 8. Scenario-specific check 3:** Hunt for the same archive name, shortcut hash and download domain across endpoints.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid "no issue" without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Extract the archive and parse shortcut target/arguments in an isolated environment.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt for the same archive name, shortcut hash and download domain across endpoints.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

010. CEO Gift-Card Request

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566 Phishing; T1656 Impersonation	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.44

Initial alert: An executive impersonation message asks an employee to purchase gift cards urgently.

Investigation objective: Validate BEC/social-engineering risk even when no malware or credential theft is involved.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Verify sender authentication and whether the executive domain/display name was spoofed.
- 7. Scenario-specific check 2:** Check whether the conversation moved to SMS/personal email or requested secrecy.
- 8. Scenario-specific check 3:** Confirm with the executive through a known channel; preserve evidence for fraud reporting and block repeat sender infrastructure.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Verify sender authentication and whether the executive domain/display name was spoofed.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Confirm with the executive through a known channel; preserve evidence for fraud reporting and block repeat sender infrastructure.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

011. Vendor Bank-Detail Change Fraud

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1566 Phishing; T1078 Valid Accounts	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.73

Initial alert: A long-standing vendor requests a change to beneficiary banking information.

Investigation objective: Distinguish legitimate business change from mailbox compromise or invoice fraud.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Compare sender headers and mailbox metadata to historical vendor communications.
- 7. Scenario-specific check 2:** Search for prior messages that may have been deleted or hidden by an attacker.
- 8. Scenario-specific check 3:** Use independent vendor verification before finance changes any beneficiary details.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare sender headers and mailbox metadata to historical vendor communications.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Use independent vendor verification before finance changes any beneficiary details.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

012. Malicious Teams Message from Trusted User

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	Email gateway / user report / collaboration audit	T1534 Internal Spearphishing; T1204 User Execution	User: a.rahman Host: WS-FIN-042 External IP: 203.0.113.91

Initial alert: A collaboration message from an internal user shares an archive and asks recipients to extract it.

Investigation objective: Determine whether the sender account/device is compromised and whether recipients executed the content.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the message and metadata:** Collect the original message, headers, attachment/link identifiers, message trace IDs and timestamps. Preserve evidence before deleting or purging the campaign.
- 2. Validate sender authenticity:** Check envelope sender, From, Reply-To, return path, authentication results, Received chain, look-alike domains and whether a trusted account may itself be compromised.
- 3. Analyse the lure safely:** Extract URLs, QR destinations and attachment metadata in an isolated workflow. Record redirect chains, final domains, file hashes and any credential-posting or download behaviour.
- 4. Identify every recipient:** Search email/collaboration telemetry for the same sender, subject, URL, attachment hash, conversation ID or file ID. Separate delivered, blocked, quarantined and user-reported copies.
- 5. Determine user interaction:** Use click tracking, proxy/browser, file-open/download and endpoint events to determine who clicked, opened, downloaded or executed. User statements help but should not replace technical evidence.
- 6. Scenario-specific check 1:** Collect collaboration audit/message metadata and file identifiers.
- 7. Scenario-specific check 2:** Analyse the archive and contained file types without executing them on production endpoints.
- 8. Scenario-specific check 3:** Correlate recipient endpoint telemetry with file download, extraction, shortcut/script execution and network connections.
- 9. Correlate identity activity:** From the interaction time, review failed/successful sign-ins, MFA prompts, token issuance, new authentication methods, inbox rules, forwarding, OAuth consent and risky session activity.
- 10. Inspect affected endpoints:** If a file was opened or code execution is possible, review process ancestry, script interpreters, file creation, persistence, security-control changes and outbound network connections.
- 11. Scope beyond the first user:** Hunt the same infrastructure, indicators and behaviours across email, DNS, proxy, EDR and identity sources. Internal forwarding or a compromised mailbox can turn one lure into a wider campaign.
- 12. Contain based on evidence:** Block malicious indicators, purge messages, revoke sessions, reset credentials, remove unauthorised MFA/OAuth/rules and isolate endpoints when execution or active C2 is supported.
- 13. Close with a defensible statement:** Document what was proven, what was not observed, the lookback window, affected users/assets, containment completed and residual risk. Avoid “no issue” without describing the evidence reviewed.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect collaboration audit/message metadata and file identifiers.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Purge malicious messages where authorised; block validated domains/URLs/files; revoke sessions and remediate credentials, MFA methods, OAuth consent or mailbox rules when identity compromise is supported; isolate endpoints when execution occurred.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate recipient endpoint telemetry with file download, extraction, shortcut/script execution and network connections.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Malware & Endpoint Compromise

EDR, process trees, file telemetry, persistence and C2

Primary evidence: EDR process/file/module/network telemetry, software inventory, proxy/DNS, persistence artefacts and authentication logs.

013. EDR Blocks Unknown Executable

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1204 User Execution; T1105 Ingress Tool Transfer	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.161

Initial alert: EDR blocks an unsigned executable launched from the user Downloads directory.

Investigation objective: Determine origin, execution status, persistence attempts and whether similar binaries exist elsewhere.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Identify parent process, command line, file creation time, signer, prevalence and initiating user.
- 7. Scenario-specific check 2:** Trace the download source through browser, proxy, email and file-transfer telemetry.
- 8. Scenario-specific check 3:** Hunt file hash, filename, certificate and behavioural indicators enterprise-wide.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify parent process, command line, file creation time, signer, prevalence and	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Evidence that raises confidence	Evidence that may support benign/contained activity
initiating user.	

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt file hash, filename, certificate and behavioural indicators enterprise-wide.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

014. Word Spawns Suspicious Child Process

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1204.002 Malicious File; T1059 Command and Scripting Interpreter	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.202

Initial alert: EDR detects WINWORD.EXE creating cmd.exe followed by a network connection.

Investigation objective: Establish whether a document triggered malicious code execution and whether a payload was retrieved.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Capture process tree and document path/hash.
- 7. Scenario-specific check 2:** Review Office child-process prevention events and command-line arguments.
- 8. Scenario-specific check 3:** Correlate outbound connections with file creation and subsequent persistence.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Capture process tree and document path/hash.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate outbound connections with file creation and subsequent persistence.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

015. LNK Launches Script Interpreter

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1204.002 Malicious File; T1059 Command and Scripting Interpreter	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.44

Initial alert: A shortcut file from an archive launches a script interpreter with hidden arguments.

Investigation objective: Determine what the shortcut executed and whether second-stage content ran.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Parse LNK target, working directory, arguments and icon path.
- 7. Scenario-specific check 2:** Review script block/process logs and any downloaded files.
- 8. Scenario-specific check 3:** Search persistence locations and outbound connections created immediately after execution.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Parse LNK target, working directory, arguments and icon path.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search persistence locations and outbound connections created immediately after execution.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

016. Signed Binary Proxy Execution

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1218 System Binary Proxy Execution	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.73

Initial alert: A trusted Windows binary is used to load or execute suspicious content.

Investigation objective: Separate legitimate administration from living-off-the-land abuse.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Confirm binary path/signature and full command line.
- 7. Scenario-specific check 2:** Identify unusual parent/child relationships and user context.
- 8. Scenario-specific check 3:** Correlate network/file activity with the signed binary execution and compare against baseline.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Confirm binary path/signature and full command line.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate network/file activity with the signed binary execution and compare against baseline.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

017. Browser Downloaded Infostealer

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1555 Credentials from Password Stores; T1041 Exfiltration Over C2 Channel	User: admin.ops Host: SRV-WEB-01 External IP: 203.0.113.91

Initial alert: A browser download is followed by credential-store and browser-profile access alerts.

Investigation objective: Determine whether an information stealer executed and what data may have been collected.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Trace download URL, file hash, browser process and user action.
- 7. Scenario-specific check 2:** Review access to browser credential stores, cookies, crypto wallets and local application data.
- 8. Scenario-specific check 3:** Check outbound connections, archive creation and newly created scheduled tasks or registry autoruns.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Trace download URL, file hash, browser process and user action.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check outbound connections, archive creation and newly created scheduled tasks or registry autoruns.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

018. USB-Delivered Malware

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1091 Replication Through Removable Media	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.161

Initial alert: EDR detects a suspicious executable launched from removable media.

Investigation objective: Scope removable-media exposure and determine whether execution or propagation occurred.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Identify USB serial/device metadata and all hosts where it was mounted.
- 7. Scenario-specific check 2:** Review file copies from removable media and process execution from drive-letter paths.
- 8. Scenario-specific check 3:** Hunt for autorun-like behaviour, shortcut abuse and secondary file creation.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify USB serial/device metadata and all hosts where it was mounted.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt for autorun-like behaviour, shortcut abuse and secondary file creation.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

019. Scheduled Task Persistence

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1053.005 Scheduled Task/Job: Scheduled Task	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.202

Initial alert: A new scheduled task launches an executable from a user-writable directory.

Investigation objective: Determine task creator, payload origin, privilege and persistence duration.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Collect task name, XML/arguments, creation event and creator process.
- 7. Scenario-specific check 2:** Check whether the task runs as SYSTEM or another privileged account.
- 8. Scenario-specific check 3:** Trace payload origin and every execution instance since task creation.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect task name, XML/arguments, creation event and creator process.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Trace payload origin and every execution instance since task creation.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

020. Suspicious Windows Service

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1543.003 Create or Modify System Process: Windows Service	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.44

Initial alert: A new service points to an unusual binary under ProgramData.

Investigation objective: Determine whether service creation is legitimate software deployment or malware persistence.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Collect service name, binary path, start type and creator process/account.
- 7. Scenario-specific check 2:** Validate software inventory/change records and signer reputation.
- 8. Scenario-specific check 3:** Review service start events, child processes and outbound connections.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect service name, binary path, start type and creator process/account.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review service start events, child processes and outbound connections.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

021. DLL Sideload Pattern

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1574.002 Hijack Execution Flow: DLL Side-Loading	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.73

Initial alert: A signed application loads an unsigned DLL from its working directory and then connects externally.

Investigation objective: Confirm sideloading and identify the malicious DLL origin.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Review module-load telemetry for path/signature anomalies.
- 7. Scenario-specific check 2:** Compare application installation path with expected vendor layout.
- 8. Scenario-specific check 3:** Hunt the DLL hash and same side-by-side filename pattern across endpoints.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review module-load telemetry for path/signature anomalies.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt the DLL hash and same side-by-side filename pattern across endpoints.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

022. MSHA Executes Remote Content

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1218.005 System Binary Proxy Execution: Mshta	User: j.tan Host: LAP-SALES-118 External IP: 203.0.113.91

Initial alert: mshta.exe starts from a browser or Office process and reaches an external domain.

Investigation objective: Determine whether remote script/HTML application content executed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Capture full mshta command line and URL.
- 7. Scenario-specific check 2:** Review child processes, temporary files and script-engine activity.
- 8. Scenario-specific check 3:** Block/hunt the remote domain and look for persistence after mshta execution.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Capture full mshta command line and URL.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Block/hunt the remote domain and look for persistence after mshta execution.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

023. Archive Extraction Followed by Payload

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1140 Deobfuscate/Decode Files or Information; T1204.002 Malicious File	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.161

Initial alert: A password-protected archive is extracted and an executable launches minutes later.

Investigation objective: Reconstruct the user action and identify all extracted components.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Review archive path, extraction tool command line and resulting files.
- 7. Scenario-specific check 2:** Identify which extracted item executed and its parent process.
- 8. Scenario-specific check 3:** Correlate network, registry and scheduled-task changes after execution.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review archive path, extraction tool command line and resulting files.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate network, registry and scheduled-task changes after execution.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

024. C2 Beacon After Quarantined File

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / antivirus / SIEM	T1071 Application Layer Protocol; T1547 Boot or Logon Autostart Execution	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.202

Initial alert: EDR quarantines a file but the host continues periodic outbound connections.

Investigation objective: Determine whether a second-stage component or persistence remains after quarantine.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the detection:** Confirm EDR disposition, detection time, host, user, file/process path and whether the object was blocked, quarantined, merely detected or actually executed.
- 2. Build the process tree:** Capture parent, child and sibling processes, command lines, integrity level, signer, hashes and user context. Process ancestry often explains whether the alert is user-driven, administrative or malicious.
- 3. Establish file provenance:** Determine how the file arrived: browser, email, archive, USB, network share, software deployment, remote tool or another process. Record first-seen and creation/modification timestamps.
- 4. Inspect execution and persistence:** Review scheduled tasks, services, autoruns, startup folders, registry changes, WMI/event subscriptions and other persistence relevant to the host.
- 5. Review network behaviour:** Identify DNS queries, direct IP connections, proxy requests, TLS destinations, beacon cadence and remote services used by the process or its children.
- 6. Scenario-specific check 1:** Do not assume quarantine equals remediation; inspect active processes and persistence.
- 7. Scenario-specific check 2:** Characterise beacon interval, destination and process ownership.
- 8. Scenario-specific check 3:** Search memory/module/network telemetry for surviving components and isolate if active C2 is confirmed.
- 9. Check credential and discovery activity:** Look for LSASS access, browser credential access, account discovery, network/share discovery, privilege checks or token manipulation after execution.
- 10. Hunt enterprise-wide:** Search hashes, filenames, signer/certificate, paths, domains, command-line fragments and behavioural patterns across EDR/SIEM. Include near-matches when malware may be repacked.
- 11. Assess impact and scope:** Determine whether the event stayed on one endpoint, created persistence, obtained credentials, moved laterally, accessed sensitive data or established C2.
- 12. Contain and eradicate:** Isolate active compromised hosts, kill/quarantine malicious processes/files, remove persistence and block infrastructure according to authority. Reimage when trust cannot be restored reliably.
- 13. Document closure evidence:** State whether execution was confirmed, how far the malware progressed, which controls stopped it, what remediation was completed and what monitoring/hunting remains.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Do not assume quarantine equals remediation; inspect active processes and persistence.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Isolate hosts with active malicious execution/C2, quarantine or remove payloads, eradicate persistence, block infrastructure, reset exposed credentials and rebuild systems when trust cannot be re-established.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search memory/module/network telemetry for surviving components and isolate if active C2 is confirmed.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Credential Abuse & Identity Attacks

Authentication, MFA, privilege, tokens and account takeover

Primary evidence: identity sign-ins, MFA/audit logs, Conditional Access, VPN, mailbox/cloud audit, endpoint credential-theft telemetry.

025. Password Spray Against Cloud Accounts

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1110.003 Password Spraying	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.44

Initial alert: Identity protection detects low-and-slow failures across many users from one source range.

Investigation objective: Determine whether any sprayed account was successfully authenticated.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Group failures by source IP, user, application and time; look for one/few attempts per account.
- 7. Scenario-specific check 2:** Search for successful sign-ins from the same infrastructure after the failure pattern.
- 8. Scenario-specific check 3:** Check MFA outcomes, token issuance and downstream mailbox/cloud activity for any successful account.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Group failures by source IP, user, application and time; look for one/few attempts per	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Evidence that raises confidence	Evidence that may support benign/contained activity
account.	

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check MFA outcomes, token issuance and downstream mailbox/cloud activity for any successful account.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

026. Brute Force Followed by Success

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1110 Brute Force; T1078 Valid Accounts	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.73

Initial alert: A user account shows hundreds of failures and then one successful login.

Investigation objective: Decide whether the success is attacker access, user recovery, or an automated service.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Build a minute-by-minute authentication timeline.
- 7. Scenario-specific check 2:** Compare successful source, user agent, device and protocol with the preceding failures.
- 8. Scenario-specific check 3:** Review post-login actions, session duration and privilege-sensitive operations.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Build a minute-by-minute authentication timeline.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review post-login actions, session duration and privilege-sensitive operations.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

027. Impossible Travel Sign-In

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1078 Valid Accounts	User: m.lim Host: SRV-FILE-02 External IP: 203.0.113.91

Initial alert: The same account authenticates from distant geographies within an impossible time window.

Investigation objective: Distinguish attacker activity from VPN, proxy, mobile carrier or cloud egress effects.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Compare IP ownership/ASN and whether one address belongs to a corporate VPN or security proxy.
- 7. Scenario-specific check 2:** Review device IDs, user agents, authentication strength and session/token continuity.
- 8. Scenario-specific check 3:** Check post-authentication activity for evidence of data access or configuration change.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare IP ownership/ASN and whether one address belongs to a corporate VPN or security proxy.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check post-authentication activity for evidence of data access or configuration change.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

028. MFA Fatigue / Push Bombing

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1621 Multi-Factor Authentication Request Generation	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.161

Initial alert: A user receives repeated MFA prompts followed by an approval.

Investigation objective: Determine whether the approval granted attacker access.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Review MFA event timestamps, method, source IP and associated sign-in.
- 7. Scenario-specific check 2:** Contact the user quickly to establish whether approval was intentional.
- 8. Scenario-specific check 3:** Invalidate active sessions and review account changes if an unexpected approval succeeded.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review MFA event timestamps, method, source IP and associated sign-in.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Invalidate active sessions and review account changes if an unexpected approval succeeded.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

029. New MFA Method Added

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1098 Account Manipulation	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.202

Initial alert: Identity audit logs show a new phone, authenticator or passkey registration.

Investigation objective: Determine whether the user or an attacker added a persistence method.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Identify registration source IP, session and preceding authentication method.
- 7. Scenario-specific check 2:** Compare with helpdesk tickets/device enrolment activity.
- 8. Scenario-specific check 3:** Review subsequent sign-ins using the new method and remove unauthorised factors.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify registration source IP, session and preceding authentication method.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review subsequent sign-ins using the new method and remove unauthorised factors.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

030. Mailbox Rules After Account Takeover

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1114 Email Collection; T1098 Account Manipulation	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.44

Initial alert: A hidden inbox rule forwards or deletes security/finance messages.

Investigation objective: Establish compromise timeline and attacker objectives.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Enumerate all rules including hidden/forwarding rules and creation timestamps.
- 7. Scenario-specific check 2:** Review sign-ins and token activity immediately before rule creation.
- 8. Scenario-specific check 3:** Search mailbox access, sent items and finance-related conversations during the exposure window.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Enumerate all rules including hidden/forwarding rules and creation timestamps.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search mailbox access, sent items and finance-related conversations during the exposure window.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

031. Service Account Interactive Logon

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1078.002 Valid Accounts: Domain Accounts	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.73

Initial alert: A non-human service account logs on interactively to a workstation.

Investigation objective: Determine misuse, credential theft, or an undocumented administrative practice.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Validate expected logon types, source hosts and service dependencies.
- 7. Scenario-specific check 2:** Check whether the account is privileged and whether passwords are shared/rotated.
- 8. Scenario-specific check 3:** Review commands/processes executed under the account and any lateral movement.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Validate expected logon types, source hosts and service dependencies.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review commands/processes executed under the account and any lateral movement.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

032. Dormant Account Reactivated

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1078 Valid Accounts	User: svc_reports Host: SRV-APP-03 External IP: 203.0.113.91

Initial alert: An account unused for months authenticates and accesses internal resources.

Investigation objective: Determine whether reactivation was authorised or represents attacker use of stale credentials.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Check HR/identity lifecycle status and recent password reset/change history.
- 7. Scenario-specific check 2:** Identify source device/IP and compare with past legitimate usage.
- 8. Scenario-specific check 3:** Review resources accessed and any privilege/group changes after reactivation.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Check HR/identity lifecycle status and recent password reset/change history.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review resources accessed and any privilege/group changes after reactivation.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

033. Privileged Admin Login from New Host

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1078 Valid Accounts; T1484 Domain or Tenant Policy Modification	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.161

Initial alert: A domain/cloud administrator authenticates from a workstation never used for administration.

Investigation objective: Validate the admin session and assess credential compromise.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Confirm whether the endpoint is a privileged access workstation or approved jump host.
- 7. Scenario-specific check 2:** Review logon type, source process, MFA and device compliance.
- 8. Scenario-specific check 3:** Correlate subsequent directory, policy, security-tool and remote-execution changes.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Confirm whether the endpoint is a privileged access workstation or approved jump host.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate subsequent directory, policy, security-tool and remote-execution changes.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

034. Kerberoasting Indicators

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1558.003 Steal or Forge Kerberos Tickets: Kerberoasting	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.202

Initial alert: A workstation requests an unusual volume of service tickets for SPN accounts.

Investigation objective: Determine whether the behaviour is legitimate discovery or credential cracking preparation.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Identify requesting user/host and affected SPNs.
- 7. Scenario-specific check 2:** Compare request volume/encryption types with baseline and administrative tooling.
- 8. Scenario-specific check 3:** Review prior process execution for directory enumeration tools and follow-on authentication attempts.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify requesting user/host and affected SPNs.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review prior process execution for directory enumeration tools and follow-on authentication attempts.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

035. Suspicious LSASS Access

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1003.001 OS Credential Dumping: LSASS Memory	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.44

Initial alert: EDR reports a process opening LSASS with memory-read rights.

Investigation objective: Determine whether credentials may have been dumped.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Validate process signer, path, parent and access rights to LSASS.
- 7. Scenario-specific check 2:** Check security-product or backup-tool allowlists carefully; do not close on name alone.
- 8. Scenario-specific check 3:** Look for dump-file creation, credential-dumping indicators and subsequent lateral authentication.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Validate process signer, path, parent and access rights to LSASS.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Look for dump-file creation, credential-dumping indicators and subsequent lateral authentication.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

036. Leaked Corporate Credentials Found Externally

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Identity provider / SIEM / UEBA	T1078 Valid Accounts; T1589 Gather Victim Identity Information	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.73

Initial alert: Threat intelligence identifies an employee email/password pair in a third-party credential leak.

Investigation objective: Determine whether the credential is current, reused and exploited against corporate services.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Characterise the authentication anomaly:** Record user, source IP/ASN, geo, application, protocol, device, MFA method, success/failure, risk level and session/token identifiers.
- 2. Build a complete sign-in timeline:** Include failures, successes, password changes, MFA prompts, token refreshes, VPN sessions and cloud/application logins before and after the alert.
- 3. Compare with user baseline:** Check normal locations, devices, working patterns and administrative roles. Avoid relying on geography alone because VPNs, mobile carriers and proxies can distort location.
- 4. Examine authentication strength:** Determine whether MFA was challenged, bypassed, satisfied by token/session reuse or weakened through legacy authentication. Review Conditional Access or equivalent policy decisions.
- 5. Look for account persistence:** Check new MFA methods, app passwords, OAuth grants, forwarding rules, delegated access, API keys, service-principal credentials or newly trusted devices.
- 6. Scenario-specific check 1:** Validate the affected identity and credential age without attempting unsafe external login.
- 7. Scenario-specific check 2:** Force credential reset/session invalidation according to policy and check MFA status.
- 8. Scenario-specific check 3:** Hunt historical sign-ins, VPN access and mailbox/cloud activity for suspicious use before the leak was discovered.
- 9. Review post-authentication actions:** Inspect email, cloud files, directory changes, remote access, administrative actions, data downloads and security-setting changes performed by the suspicious session.
- 10. Scope related identities and infrastructure:** Search the source infrastructure against other accounts and the affected account against other sources. Password spray and shared attacker infrastructure often reveal a broader campaign.
- 11. Contain the identity:** Revoke sessions/tokens, reset credentials, remove unauthorised authentication methods/grants, disable the account temporarily when necessary and protect privileged accounts with a stronger recovery path.
- 12. Validate endpoints if credential theft is possible:** If compromise may have originated from a managed device, inspect it for infostealers, credential dumping, malicious browser extensions or phishing artefacts.
- 13. Close with identity assurance:** Document the first suspicious authentication, whether access succeeded, what the attacker did, how persistence was removed and how the account was safely returned to service.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Validate the affected identity and credential age without attempting unsafe external login.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate suspicious sessions, revoke tokens, reset credentials, remove malicious authentication methods/consent/rules, protect privileged accounts and inspect likely credential-theft endpoints.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt historical sign-ins, VPN access and mailbox/cloud activity for suspicious use before the leak was discovered.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

VPN & Remote Access

Remote access, device posture, assigned IPs and internal pivots

Primary evidence: VPN concentrator, MFA/device posture, assigned tunnel IP, firewall/DNS, server authentication and user baseline.

037. VPN Login from Unusual Country

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1133 External Remote Services; T1078 Valid Accounts	User: n.sofia Host: WS-HR-017 External IP: 203.0.113.91

Initial alert: Remote-access VPN accepts a login from a geography not associated with the user.

Investigation objective: Determine whether this is legitimate travel, proxy use, or credential compromise.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Review VPN source IP/ASN/geolocation, device certificate/posture and MFA outcome.
- 7. Scenario-specific check 2:** Compare with identity/cloud sign-ins and user travel records where appropriate.
- 8. Scenario-specific check 3:** Inspect resources accessed during the VPN session and terminate if compromise is likely.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review VPN source IP/ASN/geolocation, device certificate/posture and MFA outcome.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect resources accessed during the VPN session and terminate if compromise is likely.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

038. Concurrent VPN Sessions

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1133 External Remote Services	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.161

Initial alert: The same user maintains simultaneous VPN sessions from different networks.

Investigation objective: Assess account sharing, roaming, split-device use or attacker access.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Compare session start/end times, source IPs, device identifiers and assigned internal IPs.
- 7. Scenario-specific check 2:** Check whether the VPN concentrator permits legitimate session handoff or multiple devices.
- 8. Scenario-specific check 3:** Correlate each session with internal destinations and authentication context.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare session start/end times, source IPs, device identifiers and assigned internal IPs.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate each session with internal destinations and authentication context.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

039. VPN Success After Password Spray

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	VPN concentrator / IAM / SIEM	T1110.003 Password Spraying; T1133 External Remote Services	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.202

Initial alert: Cloud/VPN logs show spraying followed by successful remote-access authentication.

Investigation objective: Determine whether the attacker converted credential guessing into network access.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Link the successful login to the spraying source/range and username.
- 7. Scenario-specific check 2:** Review MFA and device posture; identify assigned VPN IP.
- 8. Scenario-specific check 3:** Pivot from assigned VPN IP into firewall, DNS, server and authentication logs for internal activity.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Link the successful login to the spraying source/range and username.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Pivot from assigned VPN IP into firewall, DNS, server and authentication logs for internal activity.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

040. Legacy VPN Protocol Use

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1133 External Remote Services	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.44

Initial alert: A user connects through an older or exception-based remote-access protocol.

Investigation objective: Validate whether protocol use is authorised and whether controls such as MFA/device posture were bypassed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Identify protocol, authentication method and policy applied.
- 7. Scenario-specific check 2:** Check exception/change records and compare with user baseline.
- 8. Scenario-specific check 3:** Review internal access for privileged or unusual destinations.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify protocol, authentication method and policy applied.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review internal access for privileged or unusual destinations.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

041. Impossible Travel Across VPN and SaaS

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1078 Valid Accounts; T1133 External Remote Services	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.73

Initial alert: The account appears on corporate VPN and a cloud service from distant locations simultaneously.

Investigation objective: Determine whether one session represents token theft while the other is legitimate.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Remember that SaaS may see VPN egress, proxy egress or direct device IPs; map the architecture first.
- 7. Scenario-specific check 2:** Compare session/device IDs and authentication times.
- 8. Scenario-specific check 3:** Review cloud activity and VPN internal traffic separately before declaring compromise.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Remember that SaaS may see VPN egress, proxy egress or direct device IPs; map the architecture first.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review cloud activity and VPN internal traffic separately before declaring compromise.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

042. High Data Transfer Over VPN

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1048 Exfiltration Over Alternative Protocol	User: a.rahman Host: WS-FIN-042 External IP: 203.0.113.91

Initial alert: A remote user transfers an unusually large volume of data through VPN.

Investigation objective: Determine whether transfer is legitimate work, backup/sync activity, or exfiltration.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Quantify bytes, destinations, protocols and time period against the user baseline.
- 7. Scenario-specific check 2:** Identify file-server, database or repository sources accessed in the same session.
- 8. Scenario-specific check 3:** Correlate with DLP, file-access, endpoint archive creation and cloud-upload telemetry.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Quantify bytes, destinations, protocols and time period against the user baseline.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate with DLP, file-access, endpoint archive creation and cloud-upload telemetry.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

043. Privileged VPN Login After Hours

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	VPN concentrator / IAM / SIEM	T1078 Valid Accounts; T1133 External Remote Services	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.161

Initial alert: A privileged account starts remote access during an unusual time window.

Investigation objective: Determine whether emergency administration or unauthorised access occurred.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Validate on-call/change context and source device.
- 7. Scenario-specific check 2:** Review MFA method, device compliance and internal administrative destinations.
- 8. Scenario-specific check 3:** Inspect commands/configuration changes performed during the session.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Validate on-call/change context and source device.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect commands/configuration changes performed during the session.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

044. VPN from Hosting / Anonymous Infrastructure

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	VPN concentrator / IAM / SIEM	T1133 External Remote Services; T1090 Proxy	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.202

Initial alert: A valid VPN login originates from a commercial hosting provider or anonymisation network.

Investigation objective: Assess whether the account is being used through attacker infrastructure.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the remote-access event:** Record VPN user, source IP/ASN/geo, device certificate/posture, MFA result, client version, tunnel type, session ID and assigned internal IP.
- 2. Compare with identity telemetry:** Correlate the same user with directory/cloud authentication to identify spraying, impossible travel, token activity or password changes.
- 3. Map the session to internal traffic:** Use the VPN-assigned IP and session window to pivot into firewall, DNS, proxy, server and authentication logs.
- 4. Review user/device baseline:** Check whether the user normally uses this device, ISP, geography and working hours. Validate approved travel or support scenarios when relevant.
- 5. Inspect resource access:** Identify RDP, SMB, SSH, database, admin portal, file share and application access during the session.
- 6. Scenario-specific check 1:** Enrich source ASN/provider and compare with known corporate VPN/proxy services.
- 7. Scenario-specific check 2:** Review device certificate/posture and MFA context for strong corroboration.
- 8. Scenario-specific check 3:** Check for rapid follow-on discovery, RDP/SMB, privileged access or data transfer.
- 9. Look for discovery and lateral movement:** Search for scanning, repeated authentication, remote-service use, share enumeration and privilege escalation after VPN entry.
- 10. Check data movement:** Quantify upload/download volume and access to sensitive repositories, especially when the session is long or anomalous.
- 11. Scope other accounts from the source:** Search the same IP/range/device fingerprint for other remote-access attempts and successful logins.
- 12. Contain remote access:** Terminate suspicious sessions, block source infrastructure where appropriate, reset/revoke credentials and isolate associated endpoints if compromise is supported.
- 13. Close with remote-access scope:** Document how the session was authenticated, internal assets reached, actions observed, containment and whether further monitoring is required.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Enrich source ASN/provider and compare with known corporate VPN/proxy services.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Terminate the tunnel, revoke/reset the account as appropriate, block malicious source infrastructure, isolate involved endpoints and review all resources reached from the VPN-assigned IP.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check for rapid follow-on discovery, RDP/SMB, privileged access or data transfer.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

DNS & Network Resolution

Resolver behaviour, rare domains, tunnelling and C2

Primary evidence: recursive DNS/passive DNS, EDR process attribution, proxy/firewall/TLS, threat intelligence and endpoint timeline.

045. Domain Generation Algorithm Pattern

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1568.002 Dynamic Resolution: Domain Generation Algorithms	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.44

Initial alert: DNS monitoring sees one host querying many random-looking domains with few successful responses.

Investigation objective: Determine whether the pattern is malware DGA, software telemetry or a misconfigured application.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Calculate NXDOMAIN ratio, query entropy/length and periodicity.
- 7. Scenario-specific check 2:** Identify owning process through EDR/network telemetry where possible.
- 8. Scenario-specific check 3:** Compare domains with enterprise-wide prevalence and threat intelligence.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Calculate NXDOMAIN ratio, query entropy/length and periodicity.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Compare domains with enterprise-wide prevalence and threat intelligence.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

046. Possible DNS Tunnelling

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1071.004 Application Layer Protocol: DNS	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.73

Initial alert: A workstation generates long, high-entropy subdomain queries to one parent domain.

Investigation objective: Determine whether DNS is carrying encoded command-and-control or exfiltration data.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Measure label length, query volume, record types and request/response sizes.
- 7. Scenario-specific check 2:** Identify process initiating DNS activity and whether direct resolver access bypasses enterprise DNS.
- 8. Scenario-specific check 3:** Inspect parent-domain age/reputation and correlate with sensitive-file access or staging.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Measure label length, query volume, record types and request/response sizes.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect parent-domain age/reputation and correlate with sensitive-file access or staging.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

047. Newly Registered Domain Contact

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1583.001 Acquire Infrastructure: Domains; T1071.001 Web Protocols	User: admin.ops Host: SRV-WEB-01 External IP: 203.0.113.91

Initial alert: A host resolves a domain registered very recently and then establishes outbound TLS.

Investigation objective: Determine whether the domain is malicious or a legitimate new service.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Enrich registration age, certificate details, passive DNS and organisational ownership.
- 7. Scenario-specific check 2:** Identify first-seen host/process and referring URL/email.
- 8. Scenario-specific check 3:** Search enterprise prevalence and subsequent process/file activity.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Enrich registration age, certificate details, passive DNS and organisational ownership.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search enterprise prevalence and subsequent process/file activity.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

048. Dynamic DNS Service Usage

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1568 Dynamic Resolution	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.161

Initial alert: An endpoint connects to a hostname under a dynamic DNS provider.

Investigation objective: Determine whether usage belongs to approved remote access/lab activity or attacker C2.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Identify full hostname, resolver history and endpoint process.
- 7. Scenario-specific check 2:** Compare against approved remote-management software and business owner records.
- 8. Scenario-specific check 3:** Hunt same dynamic-DNS suffix and specific hostname across the environment.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify full hostname, resolver history and endpoint process.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt same dynamic-DNS suffix and specific hostname across the environment.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

049. Repeated NXDOMAIN Burst

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1568.002 Domain Generation Algorithms	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.202

Initial alert: A server suddenly produces thousands of failed DNS queries.

Investigation objective: Separate malware discovery/DGA from configuration errors or unavailable dependencies.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Group failed queries by pattern, suffix and requesting host.
- 7. Scenario-specific check 2:** Check deployment/change events and application logs for resolver failures.
- 8. Scenario-specific check 3:** Inspect process/network telemetry for randomisation, beacon cadence or new executable activity.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Group failed queries by pattern, suffix and requesting host.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect process/network telemetry for randomisation, beacon cadence or new executable activity.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

050. DNS to Known C2 Domain

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1071.004 DNS; T1102 Web Service	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.44

Initial alert: Threat intelligence matches an internal DNS query to a known command-and-control domain.

Investigation objective: Prove whether the query led to connection/execution and scope all affected hosts.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Validate indicator freshness, exact domain and potential shared hosting false positives.
- 7. Scenario-specific check 2:** Correlate DNS timestamp with proxy/firewall/TLS connection and endpoint process.
- 8. Scenario-specific check 3:** Search historical DNS and network logs for all internal sources and earliest seen time.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Validate indicator freshness, exact domain and potential shared hosting false positives.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search historical DNS and network logs for all internal sources and earliest seen time.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

051. Rare Domain After Office Process

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1204.002 Malicious File; T1071.001 Web Protocols	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.73

Initial alert: A document process is followed by DNS resolution of a domain never previously seen internally.

Investigation objective: Determine whether the document initiated malware retrieval or a benign embedded link.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Correlate process tree, document hash and DNS timestamp.
- 7. Scenario-specific check 2:** Check whether browser was launched visibly or a script/network API resolved the domain directly.
- 8. Scenario-specific check 3:** Inspect HTTP/TLS activity, downloaded files and persistence after the DNS event.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Correlate process tree, document hash and DNS timestamp.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect HTTP/TLS activity, downloaded files and persistence after the DNS event.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

052. Unexpected DNS-over-HTTPS Process

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DNS security / SIEM / NDR / EDR	T1071.004 DNS; T1090 Proxy	User: j.tan Host: LAP-SALES-118 External IP: 203.0.113.91

Initial alert: A non-browser process connects to a public DoH resolver.

Investigation objective: Determine whether malware is bypassing enterprise DNS visibility.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Validate the DNS signal:** Capture client, resolver, query name/type, response, timestamp, frequency and whether the signal comes from recursive DNS, endpoint DNS telemetry or passive network monitoring.
- 2. Characterise the pattern:** Measure prevalence, NXDOMAIN ratio, label length/entropy, periodicity, record types and whether queries are human-readable, algorithmic or encoded.
- 3. Identify the owning process:** Use EDR/network correlation to map DNS activity to a process, user and parent process whenever possible.
- 4. Enrich the domain:** Review registration age, authoritative DNS, certificate, hosting/ASN, passive DNS, threat-intelligence context and relationship to known business services.
- 5. Check follow-on connections:** A DNS query alone does not prove compromise. Correlate with proxy/firewall/TLS connections and determine whether traffic succeeded.
- 6. Scenario-specific check 1:** Identify the process, destination resolver, TLS SNI/host and command line.
- 7. Scenario-specific check 2:** Compare with approved software that legitimately implements DoH.
- 8. Scenario-specific check 3:** Hunt for direct connections to public resolvers and correlate with suspicious domain/network behaviour.
- 9. Review endpoint activity around first seen:** Look for new file/process execution, scripts, persistence, browser events or document activity that explains why the domain was queried.
- 10. Hunt prevalence and history:** Search all internal clients and historical logs for the domain, related suffixes, IPs and behavioural patterns. Identify earliest seen and most active sources.
- 11. Assess C2/exfiltration indicators:** For tunnelling or beaconing, examine cadence, request/response size, sensitive-file access, archive creation and long-running sessions.
- 12. Contain malicious resolution:** Block/sinkhole validated malicious domains where policy allows and isolate hosts showing active C2 or malware behaviour.
- 13. Close with confidence level:** Document whether the finding was malicious, suspicious-but-unconfirmed or benign, and which endpoint/network evidence supports the classification.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify the process, destination resolver, TLS SNI/host and command line.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block or sinkhole validated malicious domains, isolate hosts with confirmed C2, remove associated malware/persistence and retain DNS/network evidence for campaign scoping.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt for direct connections to public resolvers and correlate with suspicious domain/network behaviour.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

PowerShell & Script Abuse

Command-line analysis, script logging and living-off-the-land behaviour

Primary evidence: command line, PowerShell operational/script block logging, AMSI/EDR, process tree, network/file/persistence telemetry.

053. Encoded PowerShell Command

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1059.001 PowerShell; T1027 Obfuscated Files or Information	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.161

Initial alert: EDR detects powershell.exe with an encoded-command argument.

Investigation objective: Decode safely and determine what actions the script attempted.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Preserve the exact command line before decoding.
- 7. Scenario-specific check 2:** Decode content in an isolated analysis workflow; do not execute it.
- 8. Scenario-specific check 3:** Review script block/process/network/file activity corresponding to the decoded actions.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Preserve the exact command line before decoding.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review script block/process/network/file activity corresponding to the decoded actions.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

054. PowerShell Download Cradle

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1059.001 PowerShell; T1105 Ingress Tool Transfer	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.202

Initial alert: PowerShell invokes a web request to retrieve content from an external host.

Investigation objective: Determine whether downloaded content executed and created persistence.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Capture URL, user agent, destination file/in-memory execution pattern and parent process.
- 7. Scenario-specific check 2:** Correlate proxy/firewall logs and file creation with EDR telemetry.
- 8. Scenario-specific check 3:** Hunt the URL/domain and resulting payload indicators across endpoints.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Capture URL, user agent, destination file/in-memory execution pattern and parent process.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt the URL/domain and resulting payload indicators across endpoints.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

055. Hidden Window and Execution-Policy Bypass

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1059.001 PowerShell; T1027 Obfuscated Files or Information	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.44

Initial alert: PowerShell runs hidden with policy-bypass flags from a user context.

Investigation objective: Determine whether flags are part of legitimate automation or malicious stealth.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Collect full command, parent process, working directory and user.
- 7. Scenario-specific check 2:** Compare with known management scripts and code-signing expectations.
- 8. Scenario-specific check 3:** Review child processes, network connections, scheduled tasks and registry changes.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect full command, parent process, working directory and user.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review child processes, network connections, scheduled tasks and registry changes.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

056. Base64 Decode Followed by Execution

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1140 Deobfuscate/Decode Files or Information; T1059.001 PowerShell	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.73

Initial alert: PowerShell decodes a Base64 blob and invokes the resulting content.

Investigation objective: Recover the script logic without executing it and identify follow-on effects.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Extract encoded payload and decode offline.
- 7. Scenario-specific check 2:** Identify commands related to download, persistence, credential access or defence impairment.
- 8. Scenario-specific check 3:** Correlate decoded intent with actual telemetry to avoid assuming every scripted action succeeded.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Extract encoded payload and decode offline.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate decoded intent with actual telemetry to avoid assuming every scripted action succeeded.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

057. PowerShell Adds Security Exclusion

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1562.001 Impair Defenses: Disable or Modify Tools	User: m.lim Host: SRV-FILE-02 External IP: 203.0.113.91

Initial alert: A command adds an antivirus/EDR exclusion for a user-writable path.

Investigation objective: Determine whether security controls were intentionally weakened.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Identify account/process that launched PowerShell and exact exclusion path.
- 7. Scenario-specific check 2:** Review endpoint security configuration history and change-management records.
- 8. Scenario-specific check 3:** Inspect files/processes in the excluded path and restore protection when unauthorised.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify account/process that launched PowerShell and exact exclusion path.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect files/processes in the excluded path and restore protection when unauthorised.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

058. PowerShell Creates Scheduled Task

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1053.005 Scheduled Task; T1059.001 PowerShell	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.161

Initial alert: PowerShell registers a scheduled task to run a script periodically.

Investigation objective: Determine persistence intent and execution history.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Collect task XML, trigger, principal and action.
- 7. Scenario-specific check 2:** Trace script path/hash and source.
- 8. Scenario-specific check 3:** Review each task execution and any network/file activity it caused.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect task XML, trigger, principal and action.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review each task execution and any network/file activity it caused.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

059. Remote PowerShell / WinRM Activity

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1021.006 Remote Services: Windows Remote Management	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.202

Initial alert: A workstation initiates PowerShell remoting to multiple servers.

Investigation objective: Distinguish approved administration from lateral movement.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Identify initiating user/host and remote targets.
- 7. Scenario-specific check 2:** Review WinRM/PowerShell operational logs and authentication type.
- 8. Scenario-specific check 3:** Correlate with privileged logons, process creation and change tickets.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify initiating user/host and remote targets.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate with privileged logons, process creation and change tickets.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

060. Office Launches PowerShell

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1204.002 Malicious File; T1059.001 PowerShell	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.44

Initial alert: An Office application spawns PowerShell with script content.

Investigation objective: Determine whether a malicious document or add-in triggered execution.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Capture Office document/add-in details and process ancestry.
- 7. Scenario-specific check 2:** Review PowerShell script blocks and encoded arguments.
- 8. Scenario-specific check 3:** Check network retrieval, payload execution and persistence.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Capture Office document/add-in details and process ancestry.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check network retrieval, payload execution and persistence.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

061. Invoke-Expression on Downloaded Content

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1059.001 PowerShell; T1027 Obfuscated Files or Information	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.73

Initial alert: PowerShell uses dynamic execution on content obtained from a remote source.

Investigation objective: Determine whether in-memory code ran and what it changed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Reconstruct remote content from proxy/cache/EDR telemetry where available.
- 7. Scenario-specific check 2:** Review script logging/AMSI detections and child processes.
- 8. Scenario-specific check 3:** Hunt behavioural indicators because a payload hash may never exist on disk.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Reconstruct remote content from proxy/cache/EDR telemetry where available.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt behavioural indicators because a payload hash may never exist on disk.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

062. PowerShell Stages Data for Exfiltration

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	EDR / PowerShell logs / SIEM	T1560 Archive Collected Data; T1041 Exfiltration Over C2 Channel	User: svc_reports Host: SRV-APP-03 External IP: 203.0.113.91

Initial alert: PowerShell compresses files and sends them to an external web endpoint.

Investigation objective: Assess data accessed, archive contents and whether transfer completed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Preserve the exact command:** Capture full command line, host, user, parent process, working directory, integrity level and timestamps before normalisation or decoding.
- 2. Decode without execution:** If content is encoded/obfuscated, decode it offline and record both original and decoded forms. Never run unknown script content merely to understand it.
- 3. Review script telemetry:** Check PowerShell operational/script block logging, AMSI/EDR detections, transcription where enabled and command execution telemetry.
- 4. Analyse process ancestry:** Determine why PowerShell started: interactive admin, Office child process, browser, scheduled task, remote management, service or malware.
- 5. Correlate network/file actions:** Map web requests, DNS, created files, registry changes, modules and child processes to the script timeline.
- 6. Scenario-specific check 1:** Identify source file paths and archive/staging location.
- 7. Scenario-specific check 2:** Review network transfer size/destination and HTTP method.
- 8. Scenario-specific check 3:** Engage data owner/DLP process to determine sensitivity and reportable impact.
- 9. Check security-control changes:** Look for exclusions, logging changes, firewall modifications, credential access or attempts to disable/modify security tools.
- 10. Inspect persistence and lateral movement:** Review scheduled tasks, services, registry autoruns, WinRM/remoting and remote process creation.
- 11. Hunt command fragments and behaviours:** Search distinctive URLs, encoded strings, cmdlets, destination paths and process chains across the environment.
- 12. Contain based on behaviour:** Stop active malicious processes, isolate affected hosts, remove persistence, block destinations and remediate credentials when the script accessed secrets.
- 13. Close with executed-versus-intended distinction:** Clearly separate what the decoded script was capable of doing from what telemetry proves actually occurred.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify source file paths and archive/staging location.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Stop malicious script/process activity, isolate affected hosts, remove persistence, block network destinations and remediate credentials if the script accessed or dumped secrets.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Engage data owner/DLP process to determine sensitivity and reportable impact.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Ransomware & Extortion

Precursor detection, containment, lateral movement, exfiltration and impact

Primary evidence: EDR, authentication, remote execution, file-server events, backup/virtualisation logs, network transfer, directory and cloud telemetry.

063. Mass File Rename and Encryption Pattern

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1486 Data Encrypted for Impact	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.161

Initial alert: File servers report rapid extension changes and high-volume write operations.

Investigation objective: Confirm active encryption, identify patient zero and stop spread.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Identify earliest host/user performing abnormal file modifications.
- 7. Scenario-specific check 2:** Isolate affected endpoints and restrict compromised accounts as authorised.
- 8. Scenario-specific check 3:** Preserve a timeline of SMB sessions, process execution and security-control changes before remediation.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify earliest host/user performing abnormal file modifications.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Preserve a timeline of SMB sessions, process execution and security-control changes before remediation.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

064. Shadow Copy Deletion Before Impact

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / file monitoring / SIEM / user report	T1490 Inhibit System Recovery	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.202

Initial alert: A host executes commands that delete volume shadow copies shortly before file-encryption alerts.

Investigation objective: Treat precursor behaviour as high-confidence ransomware preparation.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Identify process/user executing shadow-copy deletion and parent chain.
- 7. Scenario-specific check 2:** Review adjacent commands for backup deletion, service stopping and recovery inhibition.
- 8. Scenario-specific check 3:** Scope same behaviour across endpoints immediately.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify process/user executing shadow-copy deletion and parent chain.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Scope same behaviour across endpoints immediately.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

065. Backup Services Stopped

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / file monitoring / SIEM / user report	T1562.001 Impair Defenses; T1490 Inhibit System Recovery	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.44

Initial alert: Critical backup or database protection services are stopped unexpectedly.

Investigation objective: Determine whether this is maintenance or ransomware defence impairment.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Check service-control events and initiating process/account.
- 7. Scenario-specific check 2:** Validate maintenance/change records quickly.
- 8. Scenario-specific check 3:** Search for concurrent credential abuse, remote execution, encryption tools or backup repository access.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Check service-control events and initiating process/account.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search for concurrent credential abuse, remote execution, encryption tools or backup repository access.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

066. SMB Lateral Movement Before Encryption

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1021.002 SMB/Windows Admin Shares; T1486 Data Encrypted for Impact	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.73

Initial alert: Multiple servers receive SMB connections from one workstation followed by file changes.

Investigation objective: Identify lateral movement path and compromised credentials.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Map SMB authentication events and shares accessed.
- 7. Scenario-specific check 2:** Review source host for credential theft and remote-service tooling.
- 8. Scenario-specific check 3:** Disable/contain compromised identities and hosts while preserving evidence.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Map SMB authentication events and shares accessed.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Disable/contain compromised identities and hosts while preserving evidence.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

067. PsExec-Style Ransomware Propagation

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1569.002 System Services: Service Execution; T1021.002 SMB	User: n.sofia Host: WS-HR-017 External IP: 203.0.113.91

Initial alert: Remote service creation appears on many hosts using an administrative account.

Investigation objective: Confirm remote execution mechanism and stop further propagation.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Identify remote service names/binaries and originating host.
- 7. Scenario-specific check 2:** Review authentication logs for the administrative account and privilege source.
- 8. Scenario-specific check 3:** Block/disable compromised account, isolate source and hunt remote service artefacts fleet-wide.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify remote service names/binaries and originating host.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Block/disable compromised account, isolate source and hunt remote service artefacts fleet-wide.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

068. RDP Intrusion Followed by Encryption

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1021.001 Remote Services: RDP; T1486 Data Encrypted for Impact	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.161

Initial alert: An externally exposed system shows unusual RDP access followed by ransomware activity.

Investigation objective: Reconstruct initial access and determine whether attackers moved further into the network.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Review RDP gateway/firewall/authentication logs and source infrastructure.
- 7. Scenario-specific check 2:** Check account compromise and privileges used.
- 8. Scenario-specific check 3:** Trace lateral movement, credential access and data staging prior to encryption.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review RDP gateway/firewall/authentication logs and source infrastructure.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Trace lateral movement, credential access and data staging prior to encryption.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

069. Domain Admin Compromise in Ransomware Case

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1078 Valid Accounts; T1484 Domain or Tenant Policy Modification	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.202

Initial alert: A domain administrator account is used from an unusual host before widespread impact.

Investigation objective: Assess identity-plane compromise and enterprise scope.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Review how the admin credential was obtained or session hijacked.
- 7. Scenario-specific check 2:** Audit directory/group/policy changes and remote logons.
- 8. Scenario-specific check 3:** Prioritise secure identity recovery and known-good administrative access before broad restoration.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review how the admin credential was obtained or session hijacked.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Prioritise secure identity recovery and known-good administrative access before broad restoration.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

070. Large Data Staging Before Encryption

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1560 Archive Collected Data; T1530 Data from Cloud Storage	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.44

Initial alert: A server creates multi-gigabyte archives shortly before ransomware activity.

Investigation objective: Determine whether double-extortion data collection occurred.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Identify archive source files, creator process and account.
- 7. Scenario-specific check 2:** Correlate file access with sensitive repositories.
- 8. Scenario-specific check 3:** Search outbound transfers/cloud uploads and quantify likely exposed data.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify archive source files, creator process and account.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Search outbound transfers/cloud uploads and quantify likely exposed data.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

071. Exfiltration to Cloud Storage Before Ransomware

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	EDR / file monitoring / SIEM / user report	T1567.002 Exfiltration to Cloud Storage	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.73

Initial alert: Network monitoring sees large uploads to a cloud file-sharing service from a server later encrypted.

Investigation objective: Determine whether data theft preceded impact.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Identify destination service/account and upload timeline.
- 7. Scenario-specific check 2:** Correlate with archive creation and file reads.
- 8. Scenario-specific check 3:** Preserve logs and involve legal/privacy stakeholders according to incident policy when sensitive data may be involved.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify destination service/account and upload timeline.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Preserve logs and involve legal/privacy stakeholders according to incident policy when sensitive data may be involved.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

072. Safe Mode Reboot Preceding Encryption

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1562.009 Impair Defenses: Safe Mode Boot; T1486	User: a.rahman Host: WS-FIN-042 External IP: 203.0.113.91

Initial alert: Endpoints reboot into Safe Mode or altered boot configuration before security tools go offline.

Investigation objective: Determine whether attackers are attempting to impair protections before encryption.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Review boot configuration changes and initiating process/account.
- 7. Scenario-specific check 2:** Correlate security-agent stoppage with reboot events.
- 8. Scenario-specific check 3:** Hunt similar boot modifications and isolate affected hosts before they return to normal network access.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review boot configuration changes and initiating process/account.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt similar boot modifications and isolate affected hosts before they return to normal network access.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

073. Virtualisation Host Ransomware Indicators

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1486 Data Encrypted for Impact; T1490 Inhibit System Recovery	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.161

Initial alert: A virtualisation management host shows abnormal administrative sessions and VM datastore changes.

Investigation objective: Prevent broad impact to virtual infrastructure and validate management-plane compromise.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Review management API/UI/SSH logins and privileged accounts.
- 7. Scenario-specific check 2:** Identify VM power-off, snapshot deletion or datastore file modification events.
- 8. Scenario-specific check 3:** Coordinate containment carefully to avoid destroying evidence or disrupting unaffected workloads.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review management API/UI/SSH logins and privileged accounts.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Coordinate containment carefully to avoid destroying evidence or disrupting unaffected workloads.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

074. Ransom Note Found but No Encryption Observed

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Critical	EDR / file monitoring / SIEM / user report	T1486 Data Encrypted for Impact; T1491 Defacement	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.202

Initial alert: A ransom-note file appears on one host, but encryption telemetry is absent.

Investigation objective: Determine whether this is an interrupted attack, test artefact, scareware or precursor stage.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Declare severity early:** Treat encryption, recovery inhibition, widespread remote execution or domain-level compromise as potentially critical. Activate incident command/escalation according to policy.
- 2. Identify earliest malicious activity:** Build the timeline backwards from encryption or ransom note to find initial access, credential theft, discovery, staging and defence impairment.
- 3. Stop propagation:** Isolate affected endpoints/segments, disable compromised accounts and restrict remote administration according to authorised emergency procedures. Coordinate changes to avoid destroying evidence.
- 4. Protect identity and management planes:** Review privileged accounts, directory policy, remote-management tools, virtualisation consoles, backup administration and security platforms.
- 5. Assess backups and recovery systems:** Determine whether backup services, repositories, snapshots or recovery configurations were accessed, deleted or encrypted. Protect known-good recovery infrastructure.
- 6. Scenario-specific check 1:** Hash and inspect note metadata/path; identify creating process.
- 7. Scenario-specific check 2:** Search same filename/content markers across endpoints and shares.
- 8. Scenario-specific check 3:** Review preceding credential, remote-access, staging and defence-impairment activity before deciding the event is contained.
- 9. Scope lateral movement:** Map RDP, SMB, PsExec/service creation, WMI, WinRM, SSH and other remote execution/authentication paths.
- 10. Assess data theft:** Look for bulk file access, archive creation, staging directories, cloud uploads and unusual outbound transfer before encryption.
- 11. Preserve forensic evidence:** Retain logs, volatile evidence where feasible, malicious binaries/scripts, ransom notes and key system timelines. Avoid unnecessary cleanup before evidence capture.
- 12. Eradicate and recover from known-good state:** Remove attacker persistence/credentials, rebuild or restore systems according to recovery plans and validate security controls before reconnecting.
- 13. Conduct post-incident improvement:** Document root cause, control gaps, detection opportunities, recovery lessons and actions needed to reduce recurrence.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Hash and inspect note metadata/path; identify creating process.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Activate high-severity incident response, stop propagation, secure privileged identities and management planes, protect backups, preserve evidence, assess data theft, and recover from known-good states under coordinated incident command.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review preceding credential, remote-access, staging and defence-impairment activity before deciding the event is contained.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Cloud & SaaS

Cloud audit, OAuth, tokens, storage, roles and session compromise

Primary evidence: cloud audit, identity/session/token data, OAuth/service principal records, storage/mailbox logs, privileged role and policy changes.

075. Microsoft 365 Risky Sign-In with Data Access

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1078.004 Valid Accounts: Cloud Accounts	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.44

Initial alert: A risky sign-in is followed by SharePoint and Exchange access from a new session.

Investigation objective: Determine whether the user session is compromised and what cloud data was accessed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- 2. Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- 3. Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- 4. Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- 5. Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- 6. Scenario-specific check 1:** Review sign-in risk, IP/ASN, device, MFA, Conditional Access and session/token details.
- 7. Scenario-specific check 2:** Correlate Unified Audit/SharePoint/Exchange actions by session/user.
- 8. Scenario-specific check 3:** Invalidate sessions and scope data access if unauthorised.
- 9. Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- 10. Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- 11. Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- 12. Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- 13. Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review sign-in risk, IP/ASN, device, MFA, Conditional Access and session/token details.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Invalidate sessions and scope data access if unauthorised.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

076. Malicious OAuth Application Consent

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1528 Steal Application Access Token; T1098 Account Manipulation	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.73

Initial alert: A user grants a third-party app broad mail/file permissions.

Investigation objective: Assess token-based persistence and data access independent of password changes.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- 2. Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- 3. Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- 4. Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- 5. Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- 6. Scenario-specific check 1:** Review app publisher, tenant registration, consent actor and scopes.
- 7. Scenario-specific check 2:** Search service-principal/app activity and token use.
- 8. Scenario-specific check 3:** Revoke grants/credentials and hunt other users who consented to the same app.
- 9. Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- 10. Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- 11. Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- 12. Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- 13. Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review app publisher, tenant registration, consent actor and scopes.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Revoke grants/credentials and hunt other users who consented to the same app.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

077. Mass SharePoint/OneDrive Download

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1530 Data from Cloud Storage	User: admin.ops Host: SRV-WEB-01 External IP: 203.0.113.91

Initial alert: Cloud audit shows thousands of files downloaded by one account.

Investigation objective: Determine legitimate migration/sync versus compromised account or insider collection.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- 2. Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- 3. Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- 4. Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- 5. Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- 6. Scenario-specific check 1:** Quantify file count/bytes/sites and compare with historical baseline.
- 7. Scenario-specific check 2:** Identify client/app/device/session and whether access used sync tooling or API.
- 8. Scenario-specific check 3:** Engage data owner and correlate with sign-in risk, DLP and endpoint storage.
- 9. Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- 10. Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- 11. Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- 12. Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- 13. Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Quantify file count/bytes/sites and compare with historical baseline.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Engage data owner and correlate with sign-in risk, DLP and endpoint storage.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

078. External Mail Forwarding Rule

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1114 Email Collection; T1098 Account Manipulation	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.161

Initial alert: A mailbox is configured to forward messages to an external address.

Investigation objective: Determine who created the forwarding path and whether sensitive mail was exposed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- Scenario-specific check 1:** Enumerate inbox rules, mailbox forwarding configuration and transport rules.
- Scenario-specific check 2:** Review audit logs for creation actor/session and preceding sign-in.
- Scenario-specific check 3:** Estimate messages affected during the active period and remove unauthorised forwarding.
- Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Enumerate inbox rules, mailbox forwarding configuration and transport rules.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Estimate messages affected during the active period and remove unauthorised forwarding.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

079. Privileged Cloud Role Assignment

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1098 Account Manipulation; T1069 Permission Groups Discovery	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.202

Initial alert: A user or service principal receives a powerful directory/cloud role unexpectedly.

Investigation objective: Determine whether privilege escalation was authorised.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- Scenario-specific check 1:** Capture actor, target, role, scope and method of assignment.
- Scenario-specific check 2:** Validate privileged identity management/change approvals.
- Scenario-specific check 3:** Review actions taken using the role and revoke unauthorised assignment/credentials.
- Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Capture actor, target, role, scope and method of assignment.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review actions taken using the role and revoke unauthorised assignment/credentials.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

080. AWS Access Key Used from New Infrastructure

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1078.004 Valid Accounts: Cloud Accounts	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.44

Initial alert: CloudTrail shows an access key used from a new ASN/region to enumerate services.

Investigation objective: Determine whether the key leaked and what actions were performed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- Scenario-specific check 1:** Identify principal/key age, source IP, user agent and API calls.
- Scenario-specific check 2:** Check secret-management/CI pipeline exposure and recent code commits where relevant.
- Scenario-specific check 3:** Disable/rotate compromised keys and review resource modifications/data access.
- Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify principal/key age, source IP, user agent and API calls.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Disable/rotate compromised keys and review resource modifications/data access.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

081. Cloud Storage Made Public

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1530 Data from Cloud Storage; T1222 File and Directory Permissions Modification	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.73

Initial alert: A bucket/container access policy changes to allow public or anonymous access.

Investigation objective: Determine whether exposure was intentional, how long it lasted and whether objects were accessed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- 2. Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- 3. Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- 4. Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- 5. Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- 6. Scenario-specific check 1:** Review policy-change actor and source.
- 7. Scenario-specific check 2:** Identify affected objects/sensitivity and public-access duration.
- 8. Scenario-specific check 3:** Check access logs for anonymous/external retrieval and restore least privilege.
- 9. Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- 10. Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- 11. Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- 12. Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- 13. Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review policy-change actor and source.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check access logs for anonymous/external retrieval and restore least privilege.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

082. Service Principal Credential Added

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1098.001 Account Manipulation: Additional Cloud Credentials	User: j.tan Host: LAP-SALES-118 External IP: 203.0.113.91

Initial alert: A new secret/certificate is added to an automation identity.

Investigation objective: Determine whether attackers established non-user persistence.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- Scenario-specific check 1:** Identify actor/session creating the credential and its expiry.
- Scenario-specific check 2:** Review service principal permissions and subsequent API activity.
- Scenario-specific check 3:** Remove unauthorised credentials and rotate dependent secrets carefully.
- Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify actor/session creating the credential and its expiry.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Remove unauthorised credentials and rotate dependent secrets carefully.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

083. Unmanaged Device Accesses Sensitive SaaS

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1078.004 Valid Accounts: Cloud Accounts	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.161

Initial alert: CASB/identity telemetry shows sensitive access from a device outside normal management/compliance posture.

Investigation objective: Determine whether this is valid BYOD, policy bypass or account compromise.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- 2. Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- 3. Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- 4. Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- 5. Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- 6. Scenario-specific check 1:** Review device identity/compliance, browser/session and Conditional Access decision.
- 7. Scenario-specific check 2:** Compare source network and user behaviour with baseline.
- 8. Scenario-specific check 3:** Inspect downloads/sharing actions and enforce policy where required.
- 9. Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- 10. Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- 11. Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- 12. Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- 13. Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review device identity/compliance, browser/session and Conditional Access decision.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Inspect downloads/sharing actions and enforce policy where required.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

084. Session Cookie / Token Reuse

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	Cloud audit / IAM / CASB / SIEM	T1539 Steal Web Session Cookie; T1550 Use Alternate Authentication Material	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.202

Initial alert: Identity telemetry shows a valid session used from a new network without a fresh MFA event.

Investigation objective: Assess token theft or adversary-in-the-middle session replay.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture cloud identity/session context:** Record principal, source IP/ASN, device, authentication method, Conditional Access/risk, token/session identifiers and application.
- Review the cloud audit trail:** Collect provider audit events for account, API, file, mailbox, role, policy and application activity around the suspicious session.
- Check token and OAuth persistence:** Look for consent grants, refresh tokens, service-principal credentials, new API keys, trusted devices and authentication-method changes.
- Assess privilege changes:** Review role assignments, group membership, policy modifications and creation of new identities or credentials.
- Quantify data access:** Determine files, mailboxes, objects, secrets or records accessed/downloaded and whether sharing/forwarding was enabled.
- Scenario-specific check 1:** Compare session/token identifiers, device/browser fingerprint and IP changes.
- Scenario-specific check 2:** Review original authentication event and phishing indicators.
- Scenario-specific check 3:** Revoke sessions/tokens and examine actions performed by the replayed session.
- Identify non-user activity:** Distinguish user actions from applications/service principals. Password reset alone may not remove app/token persistence.
- Scope tenant/account-wide:** Search the same application, source infrastructure, consent object, token pattern or suspicious operation across other identities.
- Contain cloud persistence:** Revoke sessions/tokens, remove malicious consent/credentials/roles, rotate exposed keys and disable compromised identities where needed.
- Validate configuration after containment:** Confirm logging, access policies, external sharing, mailbox rules and privileged roles are restored to intended state.
- Close with data-impact statement:** Document what cloud access succeeded, data potentially exposed, persistence removed and residual monitoring or disclosure actions.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Compare session/token identifiers, device/browser fingerprint and IP changes.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Revoke tokens/sessions, remove malicious OAuth grants/credentials/roles, rotate keys, disable compromised identities where necessary, restore secure sharing/policy settings and quantify cloud data impact.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Revoke sessions/tokens and examine actions performed by the replayed session.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Insider Risk & Data Misuse

Legitimate access, DLP, intent-neutral evidence and governance

Primary evidence: DLP, file/repository/database audit, endpoint transfer, USB/cloud/email activity, access approvals and business context.

085. Mass Copy to Removable Media

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1052 Exfiltration Over Physical Medium	User: n.sofia Host: WS-HR-017 External IP: 192.0.2.44

Initial alert: DLP/endpoint telemetry shows an employee copying many sensitive files to USB.

Investigation objective: Determine legitimate business transfer versus unauthorised collection.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Identify files, classifications, volume, device serial and user.
- 7. Scenario-specific check 2:** Review job role, approved business need and ticket/manager context.
- 8. Scenario-specific check 3:** Preserve evidence and coordinate with HR/legal according to insider-risk policy; avoid assumptions about intent.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify files, classifications, volume, device serial and user.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Preserve evidence and coordinate with HR/legal according to insider-risk policy; avoid assumptions about intent.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

086. Upload to Personal Cloud Storage

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1567.002 Exfiltration to Cloud Storage	User: svc_reports Host: SRV-APP-03 External IP: 198.51.100.73

Initial alert: A managed endpoint uploads a large archive to a personal file-sharing account.

Investigation objective: Determine whether data policy violation or intentional exfiltration occurred.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Identify destination service/account, files, bytes and process/browser.
- 7. Scenario-specific check 2:** Correlate DLP labels and archive creation.
- 8. Scenario-specific check 3:** Validate business justification and contain according to policy if unauthorised.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify destination service/account, files, bytes and process/browser.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Validate business justification and contain according to policy if unauthorised.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

087. Departing Employee Repository Clone

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1213 Data from Information Repositories	User: m.lim Host: SRV-FILE-02 External IP: 203.0.113.91

Initial alert: A user in an offboarding window clones or downloads multiple source-code repositories.

Investigation objective: Assess legitimate handover versus excessive collection.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Review repository audit, branches/projects, clone volume and authentication tokens.
- 7. Scenario-specific check 2:** Compare with normal development activity and offboarding responsibilities.
- 8. Scenario-specific check 3:** Coordinate with management/HR and revoke unnecessary access while preserving business continuity.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review repository audit, branches/projects, clone volume and authentication tokens.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Coordinate with management/HR and revoke unnecessary access while preserving business continuity.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

088. Unusual Privileged Database Queries

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	DLP / file audit / UEBA / manager report	T1213 Data from Information Repositories	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.161

Initial alert: A database administrator runs high-volume queries against customer or financial records outside routine patterns.

Investigation objective: Determine whether the access is authorised operational work or misuse of legitimate privilege.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Review query text/objects/row counts and source client.
- 7. Scenario-specific check 2:** Validate incident/change/request context.
- 8. Scenario-specific check 3:** Correlate exports, local file creation and outbound transfer activity.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review query text/objects/row counts and source client.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Correlate exports, local file creation and outbound transfer activity.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

089. Mailbox Export / eDiscovery Activity

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1114 Email Collection	User: admin.ops Host: SRV-WEB-01 External IP: 198.51.100.202

Initial alert: A privileged user exports a large mailbox dataset.

Investigation objective: Determine whether export is authorised legal/administrative work or unauthorised collection.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Identify export job creator, scope and destination.
- 7. Scenario-specific check 2:** Validate case/ticket/approval context.
- 8. Scenario-specific check 3:** Review access to the exported package and any external transfer.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify export job creator, scope and destination.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review access to the exported package and any external transfer.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

090. After-Hours Source Code Archive

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1560 Archive Collected Data	User: a.rahman Host: WS-FIN-042 External IP: 192.0.2.44

Initial alert: A developer creates compressed archives of source code late at night and copies them outside standard paths.

Investigation objective: Assess business need and possible data staging.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Identify archive contents, size, creator process and destination path.
- 7. Scenario-specific check 2:** Compare with release/build workflows and user baseline.
- 8. Scenario-specific check 3:** Check subsequent USB/cloud/network transfer and access to secrets/configuration files.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify archive contents, size, creator process and destination path.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check subsequent USB/cloud/network transfer and access to secrets/configuration files.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

091. Repeated Security Policy Bypass Attempts

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1562.001 Impair Defenses	User: n.sofia Host: WS-HR-017 External IP: 198.51.100.73

Initial alert: A user repeatedly disables endpoint controls, uses unauthorised tools or bypasses web restrictions.

Investigation objective: Determine malicious intent, troubleshooting behaviour or policy misunderstanding based on evidence.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Correlate control-change attempts, user role and helpdesk activity.
- 7. Scenario-specific check 2:** Review tools/files executed and destinations accessed.
- 8. Scenario-specific check 3:** Escalate through defined insider-risk/governance channels rather than confronting the user independently.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Correlate control-change attempts, user role and helpdesk activity.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Escalate through defined insider-risk/governance channels rather than confronting the user independently.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

092. Legitimate Access Used to Share Sensitive Data

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	DLP / file audit / UEBA / manager report	T1530 Data from Cloud Storage	User: svc_reports Host: SRV-APP-03 External IP: 203.0.113.91

Initial alert: A user shares sensitive cloud files externally using valid permissions.

Investigation objective: Determine whether sharing is authorised, accidental or deliberate policy violation.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Start from observable facts:** Record the exact file access, copy, query, upload, share or policy action without assigning motive. Insider investigations require especially careful evidence handling.
- 2. Preserve audit evidence:** Collect endpoint, DLP, file, repository, cloud and authentication logs with timestamps and object identifiers.
- 3. Establish authorised baseline:** Understand the person's role, normal data access, project needs, approved devices/services and relevant business processes.
- 4. Quantify the activity:** Measure files/records/bytes, sensitivity, destinations, time window and whether data was merely accessed or actually transferred.
- 5. Correlate staging and transfer:** Look for archive creation, USB mounting, personal cloud use, external email, repository cloning or printing around the event.
- 6. Scenario-specific check 1:** Review share links, recipients, permissions and expiration.
- 7. Scenario-specific check 2:** Identify data classification and business owner.
- 8. Scenario-specific check 3:** Check downloads by external recipients and remediate access according to policy.
- 9. Check access changes:** Identify new permissions, unusual privilege use or attempts to bypass controls that may have enabled the activity.
- 10. Coordinate through governance channels:** Follow organisational insider-risk, HR, legal and privacy procedures. SOC should provide technical facts and preserve confidentiality.
- 11. Contain proportionately:** Restrict access, revoke sharing, block transfer paths or preserve devices when authorised. Avoid actions that exceed SOC authority.
- 12. Document alternative explanations:** Record legitimate business explanations considered and evidence that supports or contradicts each.
- 13. Close with factual findings:** State what data was accessed/transferred, where it went, what controls acted, and which non-technical stakeholders own the final intent/policy determination.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review share links, recipients, permissions and expiration.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Preserve evidence and escalate through authorised insider-risk/HR/legal channels; restrict access or sharing only within approved authority; document technical facts without assigning motive.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check downloads by external recipients and remediate access according to policy.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Web & Application Attacks

WAF, application, API, server and database correlation

Primary evidence: CDN/WAF/reverse proxy, application/API/database logs, EDR/FIM on servers, cloud metadata and network telemetry.

093. SQL Injection Attempt Against Internet Portal

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1190 Exploit Public-Facing Application	User: m.lim Host: SRV-FILE-02 External IP: 192.0.2.161

Initial alert: WAF detects SQL injection payload patterns in requests to a public application.

Investigation objective: Determine whether the attempt was blocked, reached the application, or caused database impact. Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- Scenario-specific check 1:** Review raw request, WAF action and matched rule.
- Scenario-specific check 2:** Correlate reverse-proxy/app/database logs using request ID/time/source.
- Scenario-specific check 3:** Check for errors, unusual database queries, authentication changes or data access after the request.
- Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review raw request, WAF action and matched rule.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check for errors, unusual database queries, authentication changes or data access after the request.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

094. Potential Web Shell on Server

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
High	WAF / application / EDR / SIEM	T1505.003 Server Software Component: Web Shell	User: j.tan Host: LAP-SALES-118 External IP: 198.51.100.202

Initial alert: EDR/FIM reports a new script file in a web-accessible directory and the web server spawns a shell.

Investigation objective: Determine whether a web shell was uploaded and executed.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- Scenario-specific check 1:** Collect file path/hash/creation actor and web request that preceded creation.
- Scenario-specific check 2:** Review web-server child processes and outbound connections.
- Scenario-specific check 3:** Hunt same filename/content/behaviour across web nodes and isolate affected host if active control is confirmed.
- Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Collect file path/hash/creation actor and web request that preceded creation.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Hunt same filename/content/behaviour across web nodes and isolate affected host if active control is confirmed.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

095. Directory Traversal Attempt

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1190 Exploit Public-Facing Application	User: admin.ops Host: SRV-WEB-01 External IP: 192.0.2.44

Initial alert: Web logs show encoded ../ traversal patterns targeting configuration or system files.

Investigation objective: Determine whether the application returned sensitive file content or only rejected the request.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- 2. Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- 3. Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- 4. Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- 5. Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- 6. Scenario-specific check 1:** Decode the request safely and identify targeted paths.
- 7. Scenario-specific check 2:** Review HTTP status/response size and application errors.
- 8. Scenario-specific check 3:** Check subsequent authentication or exploitation from the same source if content may have leaked.
- 9. Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- 10. Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- 11. Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- 12. Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- 13. Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Decode the request safely and identify targeted paths.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Check subsequent authentication or exploitation from the same source if content may have leaked.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

096. Credential Stuffing Against Customer Portal

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1110.004 Credential Stuffing	User: a.rahman Host: WS-FIN-042 External IP: 198.51.100.73

Initial alert: The application sees high-volume logins using many usernames from distributed IPs.

Investigation objective: Determine whether stolen credentials produced successful customer account access.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- 2. Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- 3. Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- 4. Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- 5. Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- 6. Scenario-specific check 1:** Identify rate, usernames, source infrastructure and user agents.
- 7. Scenario-specific check 2:** Separate failed attempts from successful sessions and high-risk actions.
- 8. Scenario-specific check 3:** Apply fraud/account-protection workflow for successfully accessed accounts.
- 9. Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- 10. Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- 11. Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- 12. Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- 13. Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify rate, usernames, source infrastructure and user agents.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Apply fraud/account-protection workflow for successfully accessed accounts.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

097. API Token Abuse

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1078 Valid Accounts	User: n.sofia Host: WS-HR-017 External IP: 203.0.113.91

Initial alert: API gateway logs show a valid token used from a new client/network for unusual endpoints.

Investigation objective: Determine token theft, misuse or legitimate integration change.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- 2. Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- 3. Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- 4. Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- 5. Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- 6. Scenario-specific check 1:** Identify token owner, scope, creation/rotation history and source.
- 7. Scenario-specific check 2:** Compare API methods, endpoints, volume and data returned with baseline.
- 8. Scenario-specific check 3:** Revoke/rotate token if compromised and review downstream actions.
- 9. Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- 10. Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- 11. Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- 12. Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- 13. Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify token owner, scope, creation/rotation history and source.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Revoke/rotate token if compromised and review downstream actions.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

098. Suspicious File Upload to Web Application

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1190 Exploit Public-Facing Application; T1105 Ingress Tool Transfer	User: svc_reports Host: SRV-APP-03 External IP: 192.0.2.161

Initial alert: A public application accepts an unusual executable/script-like file upload.

Investigation objective: Determine whether the file was stored, made executable or invoked server-side.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- 1. Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- 2. Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- 3. Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- 4. Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- 5. Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- 6. Scenario-specific check 1:** Review upload request, MIME/content validation and storage path.
- 7. Scenario-specific check 2:** Check whether the application renamed/sanitised the file and whether it became web-accessible.
- 8. Scenario-specific check 3:** Monitor server process creation/file execution and remove malicious content safely.
- 9. Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- 10. Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- 11. Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- 12. Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- 13. Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Review upload request, MIME/content validation and storage path.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Monitor server process creation/file execution and remove malicious content safely.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

099. Server-Side Request Forgery Attempt

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1190 Exploit Public-Facing Application	User: m.lim Host: SRV-FILE-02 External IP: 198.51.100.202

Initial alert: WAF/app logs show requests that try to make the server fetch internal or metadata-service URLs.

Investigation objective: Determine whether SSRF reached internal services or exposed cloud credentials/metadata.

Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- Scenario-specific check 1:** Identify requested target URLs/IPs and application feature abused.
- Scenario-specific check 2:** Correlate server-side outbound requests with the inbound request ID/time.
- Scenario-specific check 3:** Review cloud metadata/API calls or internal service access if the request succeeded.
- Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Identify requested target URLs/IPs and application feature abused.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Review cloud metadata/API calls or internal service access if the request succeeded.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

100. WAF Block Followed by Host Compromise Indicators

Severity	Primary alert source	MITRE ATT&CK focus	Example entities
Medium	WAF / application / EDR / SIEM	T1190 Exploit Public-Facing Application; T1059 Command and Scripting Interpreter	User: j.tan Host: LAP-SALES-118 External IP: 192.0.2.44

Initial alert: WAF blocks repeated exploit requests, but EDR later alerts on the same web server.

Investigation objective: Do not treat a WAF block as proof the attack failed; correlate application and endpoint evidence. Treat this as an evidence-building exercise, not a label. The alert provides one observable signal; the analyst must establish whether the activity was attempted, blocked, successful, persistent, or part of a wider campaign. Start with the exact alert timestamp and entities, then expand the time window as new evidence appears.

Step-by-step investigation

- Capture the inbound request:** Record source, method, URI, headers, parameters/body, timestamp, WAF rule/action, request/correlation ID and target virtual host.
- Normalise and decode safely:** Decode URL/HTML/base64/Unicode encodings for analysis without executing payloads. Preserve the original request alongside the normalised form.
- Correlate WAF and application logs:** Determine whether the request was blocked at the edge, passed to the application or was transformed by a proxy/CDN.
- Check application outcome:** Review status code, response size, errors, authentication state, server logs and application-specific events.
- Inspect server/endpoint telemetry:** Look for new files, web-server child processes, shell/script execution, privilege changes and outbound connections.
- Scenario-specific check 1:** Build a unified timeline across WAF, web/app logs and EDR.
- Scenario-specific check 2:** Search for alternate requests, encoding variants or another vulnerable endpoint that was not blocked.
- Scenario-specific check 3:** Identify process/file creation and privilege changes on the server to confirm compromise path.
- Review database/API effects:** For injection or API abuse, inspect queries, object access, token use, data returned and configuration changes.
- Scope attacker infrastructure:** Search the source IP/range, user agent, payload pattern and targeted endpoint across WAF/web logs; distributed campaigns may require behavioural grouping.
- Check follow-on activity:** Look for successful authentication, web shell access, internal scanning, cloud metadata calls or data exfiltration after the initial request.
- Contain at the correct layer:** Block malicious patterns/infrastructure, disable vulnerable functions, patch/virtually patch, rotate exposed secrets and isolate compromised servers as appropriate.
- Close with exploit-success evidence:** Explicitly state whether the request was attempted, reached the application, executed code, changed data or produced confirmed compromise.

Key pivots to run

Time pivot: expand 15 minutes before/after first, then 24 hours, then a risk-based historical lookback.

Entity pivot: search the user, host, IP, domain/file/process/application/session independently to discover related activity.

Control pivot: determine what each control actually did - allowed, blocked, detected, quarantined, challenged, reset or failed.

Campaign pivot: search for the same infrastructure, artefact or behaviour across other users and assets rather than stopping at the original alert.

Decision evidence

Evidence that raises confidence	Evidence that may support benign/contained activity
Corroborating telemetry shows the suspicious action succeeded; follow-on activity appears in a second independent source; the same entities repeat across the timeline; persistence, privilege use, lateral movement, C2, data access or configuration change is observed. For this case, give special weight to: Build a unified timeline across WAF, web/app logs and EDR.	The control clearly prevented the action before execution/access; independent telemetry shows no follow-on activity in the defined window; the behaviour matches an approved change, known application or verified user action; repeated enterprise-wide search finds no related malicious pattern.

Containment, escalation and closure

Containment: Block malicious requests/infrastructure, patch or virtually patch vulnerable paths, rotate exposed secrets, remove malicious server artefacts and isolate compromised hosts while preserving application evidence.

Escalate when: There is confirmed unauthorised access or execution, privileged identity involvement, persistence, lateral movement, active C2, sensitive-data access/exfiltration, material service impact, regulatory/privacy implications, or uncertainty that exceeds SOC authority or evidence capability.

Closure criteria: The analyst has a documented timeline and scope; malicious or unauthorised persistence is removed; affected accounts/assets are remediated; relevant indicators/behaviours are hunted across the defined environment; residual monitoring has an owner; and the final classification explains both supporting and contradicting evidence.

Detection improvement: Convert the strongest evidence from this investigation into better correlation. Candidate logic should combine the original alert with at least one higher-confidence context signal. For this scenario, consider telemetry around: Identify process/file creation and privilege changes on the server to confirm compromise path.

Analyst discipline: "Not observed" is not the same as "did not happen." Record the telemetry searched, retention/lookback, coverage gaps and confidence level behind the conclusion.

Appendix A - Evidence Source Checklist

Identity / IAM: Sign-in events, MFA results, device identity, Conditional Access, password changes, authentication-method changes, token/session IDs, privileged role/group changes.

Endpoint / EDR: Process creation, process ancestry, command lines, file creation/modification, module loads, registry, services, scheduled tasks, network connections, detections and response actions.

Email / Collaboration: Original headers, message trace, sender authentication, URL clicks, attachment hashes, mailbox rules, forwarding, Teams/Slack-like message audit and file identifiers.

Network / Firewall / Proxy: Source/destination, ports, action, bytes, URL/host, TLS metadata, NAT, VPN-assigned IPs, internal segmentation and egress.

DNS: Query name/type, response, resolver, client, NXDOMAIN, prevalence, first/last seen, process attribution where available.

Cloud / SaaS: Audit/API events, application consent, service-principal activity, file/mail access, sharing, role/policy changes, tokens/keys and resource configuration.

Web / Application / API: WAF action, raw request, request ID, app errors, session/authentication, server logs, API gateway and database queries.

Data / DLP / Repositories: File labels, shares, source code, database objects, exports, archive creation, USB/cloud transfer and external sharing.

Business context: Asset criticality, owner, change ticket, maintenance, travel/on-call, HR lifecycle, approved software and incident history.

Appendix B - Analyst Questions Before Closing Any Alert

What exact observable caused the alert, and what did the control do with it?

What is the earliest related activity I can prove?

What is the latest related activity I can prove?

Which user, host, application, IP, domain, process, file, session and business service are in scope?

Did the suspicious action succeed, or was it only attempted?

What independent telemetry corroborates the conclusion?

Was there execution, persistence, credential access, privilege change, discovery, lateral movement, collection, C2, exfiltration or impact?

Could an approved business process or security tool explain the activity?

What lookback period and log retention did I actually search?

Do telemetry gaps prevent a high-confidence conclusion?

Did I search for campaign-wide matches beyond the original user/host?

What containment actions were completed, by whom and at what time?

Have compromised sessions/tokens/credentials been invalidated rather than only passwords changed?

If a host was compromised, is it trustworthy enough to remediate in place or should it be rebuilt?

If cloud/OAuth persistence existed, was it removed independently of the user password?

If data may have been accessed, have I identified the owner, sensitivity and transfer evidence?

If the alert was blocked, is there evidence of an alternate path or prior successful activity?

What detection/logging gap did this investigation expose?

What residual risk remains after closure?

Can another analyst read my notes and reproduce the reasoning without asking me what I meant?

Appendix C - Platform-Neutral Search Patterns

Authentication burst: Group authentication events by source_ip, user and 5-15 minute window; compare failure count, success-after-failure and number of distinct accounts.

New-source successful login: Find successful authentication where source ASN/device/geo has not appeared for the user in a historical baseline window; enrich with MFA and session details.

Office-to-script chain: Search process creation where parent is an Office application and child is a script interpreter, shell, LOLBin or downloader; correlate network and file creation.

Rare domain after execution: Join process/network/DNS data for domains first seen in the environment shortly after a new or suspicious process starts.

Remote execution: Correlate privileged authentication with service creation, WinRM/WMI/RDP/SMB activity on a second host within a narrow time window.

Mass file activity: Find hosts/users with sudden increases in file rename/write/delete volume; correlate extension changes, process owner, SMB sessions and recovery-inhibition commands.

Cloud mass download: Aggregate cloud file-download events by user/session/device; compare count/bytes/sites with prior baseline and identity risk.

External forwarding: Search mailbox/tenant audit for new forwarding addresses, inbox rules or transport rules targeting external domains; correlate with sign-in anomalies.

Potential DNS tunnel: Aggregate query length, subdomain uniqueness, entropy, record types and volume by client and parent domain; identify owning process and outbound follow-on.

Web exploit success: Join WAF request ID/time/source with application errors, server process/file telemetry and database/API events; only elevate to compromise when downstream effects support it.

These are conceptual search patterns, not copy-paste vendor syntax. Adapt field names, retention and correlation keys to the organisation's SIEM, EDR, IAM, cloud and logging architecture.

Appendix D - Incident Documentation Template

Incident / Alert ID: Unique reference and related cases.

Date / Time: Detection time, first malicious activity, containment and closure.

Detection source: Rule/use case, product, reporter and raw event reference.

Affected entities: Users, hosts, applications, IPs, domains, files, cloud resources and business services.

Summary: Two to five sentences explaining what happened and current impact.

Timeline: Chronological evidence with source and timestamp.

Investigation performed: Queries, pivots, systems checked, lookback period and evidence collected.

Findings: Confirmed actions, attempted actions, not-observed activity and confidence level.

MITRE ATT&CK: Relevant tactics/techniques based on observed behaviour.

Containment / Recovery: Actions, owners, timestamps and validation.

Business / Data impact: Availability, integrity, confidentiality, customer/regulatory implications.

Root cause / Initial access: Known, suspected or unknown, with evidence.

Closure rationale: Why it is safe to close or transition to monitoring/recovery.

Lessons / Detection improvements: Rule tuning, logging gaps, control improvements, threat hunt and follow-up actions.

Appendix E - References and Version Notes

NIST SP 800-61 Rev. 3: Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile. Final April 2025. <https://csrc.nist.gov/pubs/sp/800/61/r3/final>

NIST Cybersecurity Framework 2.0: Cybersecurity risk-management framework used by SP 800-61 Rev. 3. <https://www.nist.gov/cyberframework>

MITRE ATT&CK Enterprise: Enterprise tactics, techniques and detection knowledge. This playbook was prepared against ATT&CK v19-era structure; v19.2 was released 6 August 2026. <https://attack.mitre.org/>

CISA #StopRansomware Guide: Defensive ransomware guidance including logging, centralised monitoring, containment and recovery considerations. <https://www.cisa.gov/stopransomware/ransomware-guide>